



高等計算機網絡



TCP/IP協議棧安全

李琦

清華大學網研院



本章的內容組織



第一節

TCP/IP協議工作原理

- 協議棧中消息縱向傳遞
- 協議棧中消息橫向傳遞

TCP/IP協議棧是如何工作的?



第二節

鏈路層安全

- ARP欺騙與污染
- 網絡監聽與嗅探

鏈路層存在哪些安全問題?



第三節

網絡層安全

- 源地址假冒攻擊
- IP分片攻擊原理
- ICMP攻擊原理
- IPSec協議
- 網絡入侵檢測

網絡層存在哪些安全問題?



第四節

傳輸層安全

- 拒絕服務攻擊
- TCP劫持攻擊
- TLS協議

傳輸層存在哪些安全問題?



第五節

典型案例分析

- 交互信息泄露
- 幀長側信道
- 交互二義性
- 交互語義缺失
- 交互身份欺騙
- NAT劫持

有哪些典型攻擊



第六節

網絡安全共性分析

- 網絡攻擊的共性特徵
- 協議棧設計缺陷和實現漏洞
- 協議棧安全的基本防禦原理

如何提升協議棧安全性?

協議棧各層次均存在安全問題

如何根據協議棧各層次安全問題的共性特徵提升協議棧安全性?



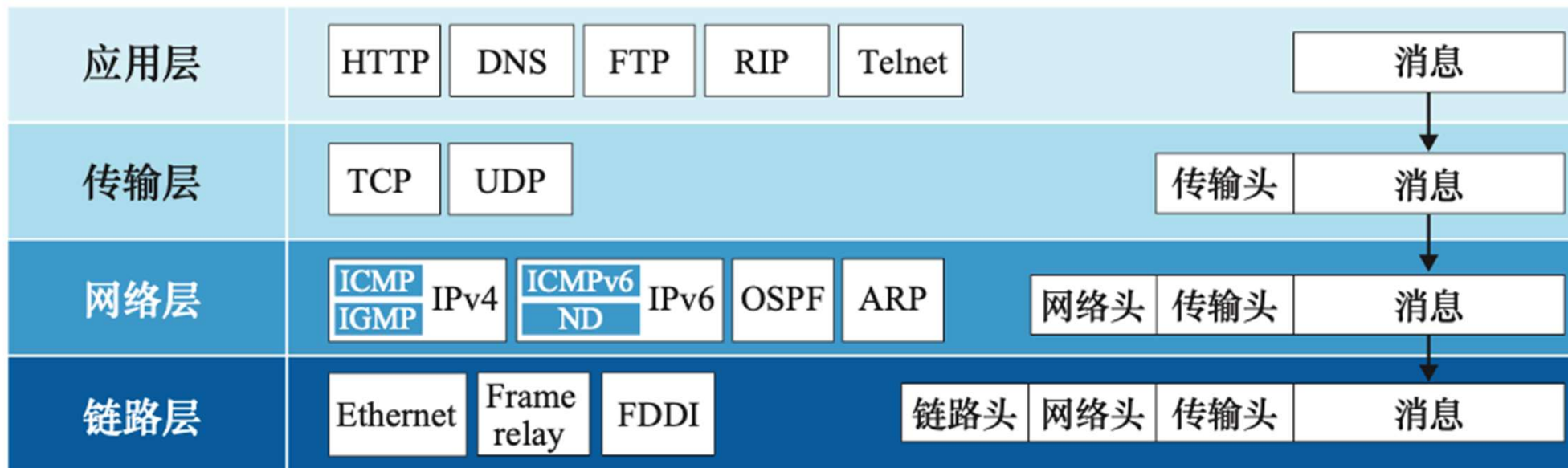
第1節 TCP/IP協議工作原理

- ✓ 協議棧中消息的縱向傳遞
- ✓ 協議棧中消息的橫向傳遞



協議棧中消息的縱向傳遞

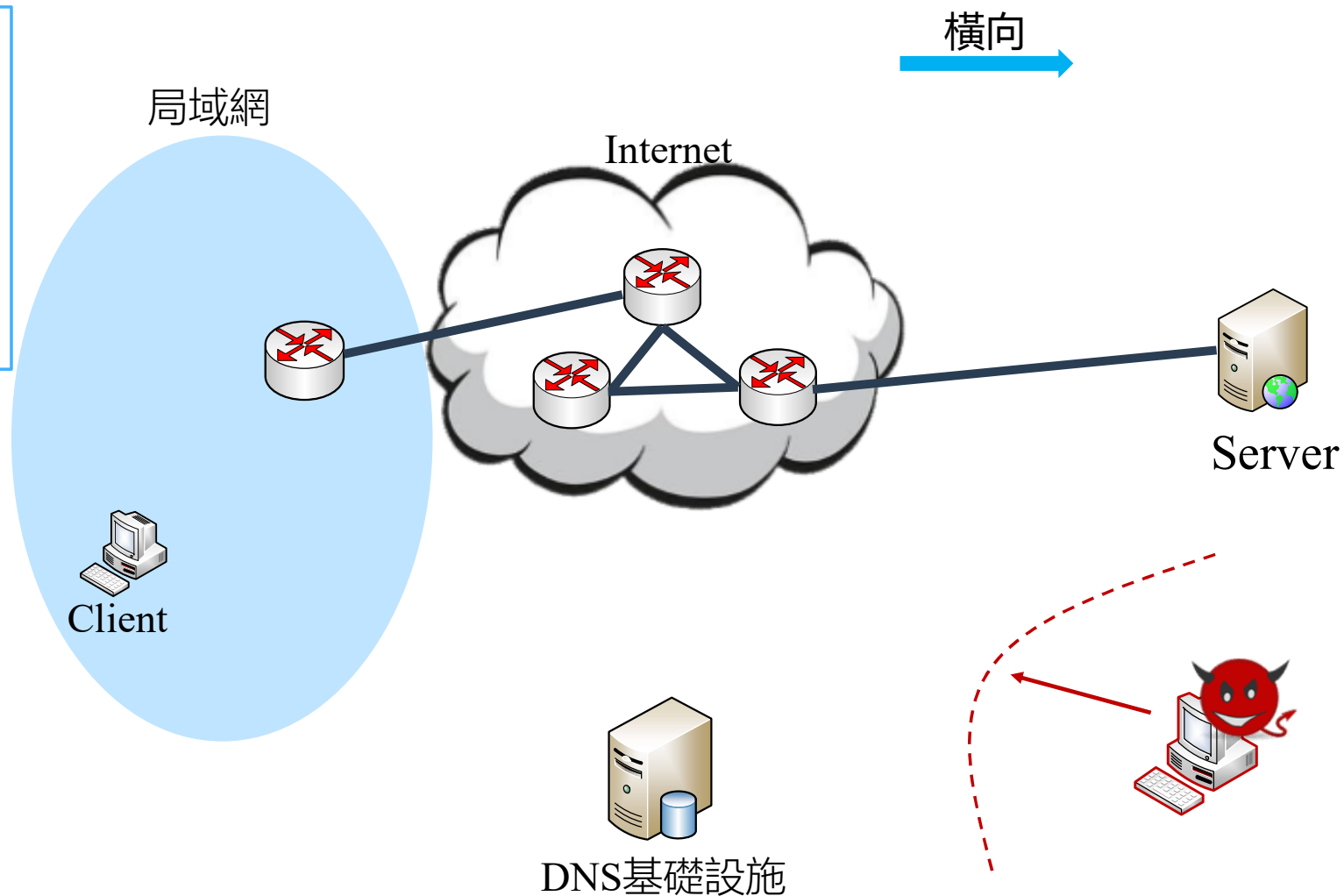
- 遵循分層模型，當前網絡系統的協議都是以棧的形式實現和部署
- 在協議棧對消息進行處理的過程中，每一層都完成自己的語義或功能，包括尋址、路由和校驗等





協議棧中消息的橫向傳遞

局域網中的Client遠程訪問 Server 時，在數據傳遞處理的每一步，都有可能產生安全問題

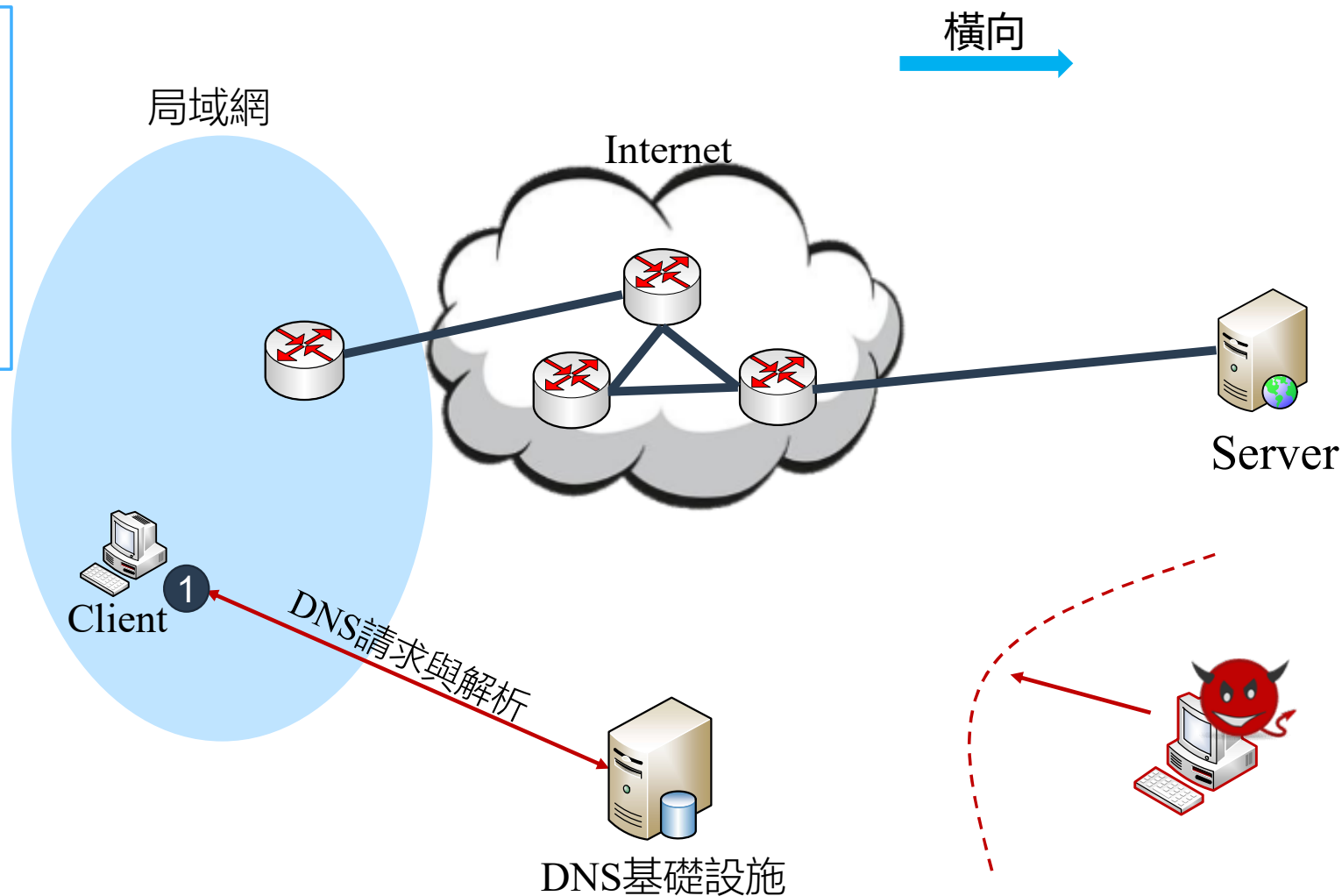




協議棧中消息的橫向傳遞

局域網中的Client遠程訪問Server時，在數據傳遞處理的每一步，都有可能產生安全問題

① DNS劫持

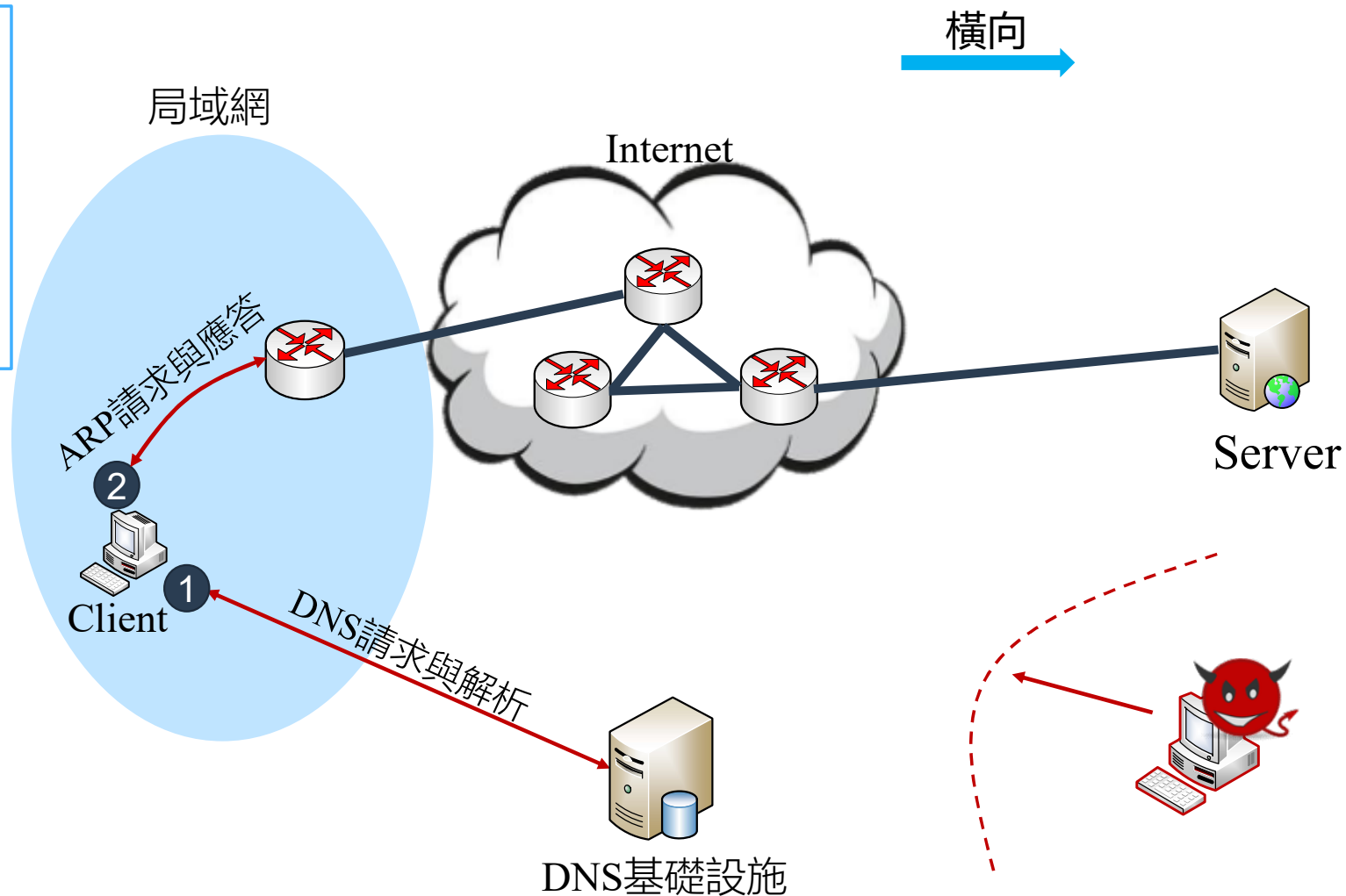




協議棧中消息的橫向傳遞

局域網中的Client遠程訪問Server時，在數據傳遞處理的每一步，都有可能產生安全問題

- 1 DNS劫持
- 2 ARP污染

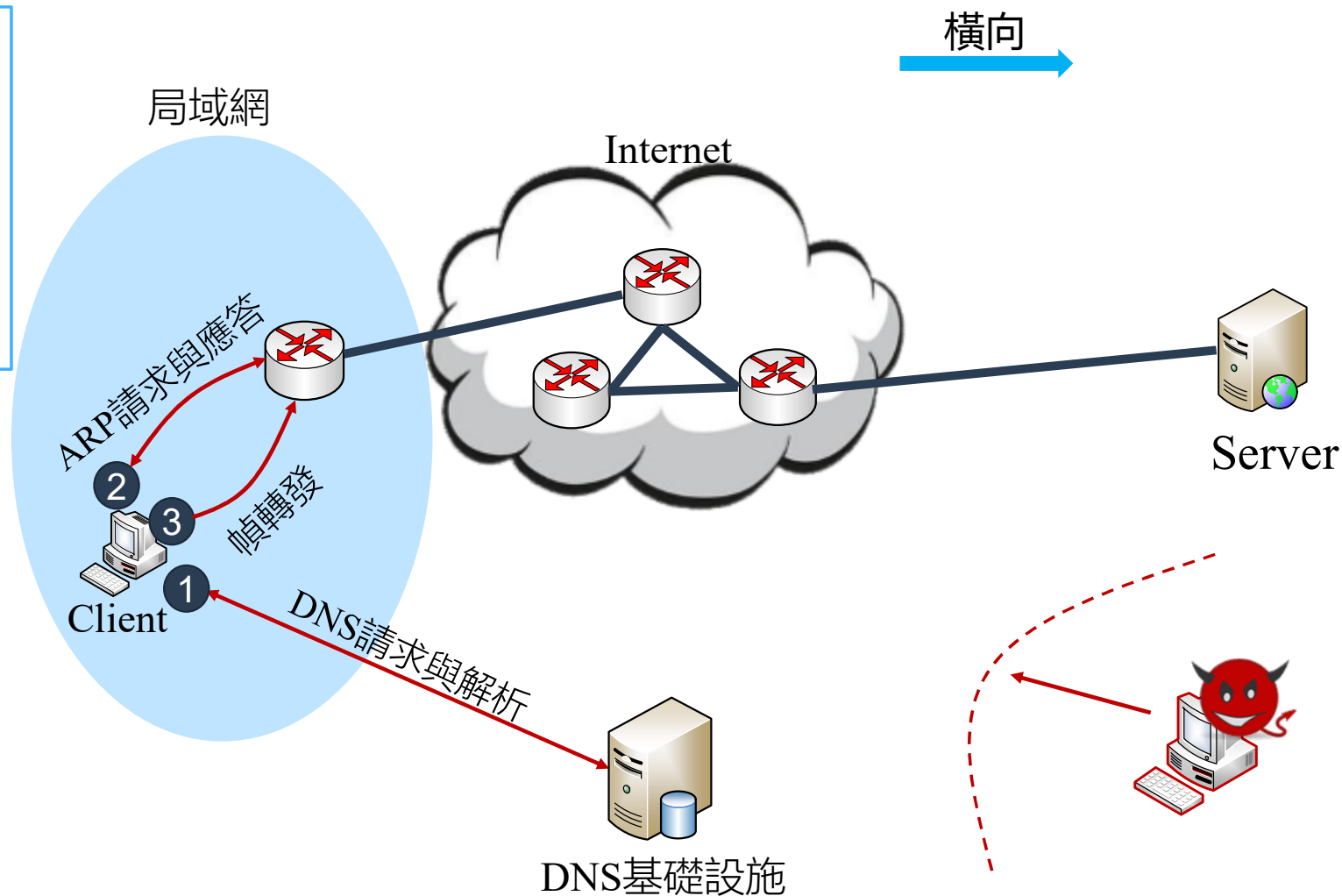




協議棧中消息的橫向傳遞

局域網中的Client遠程訪問Server時，在數據傳遞處理的每一步，都有可能產生安全問題

- 1 DNS劫持
- 2 ARP污染
- 3 嗅探監聽

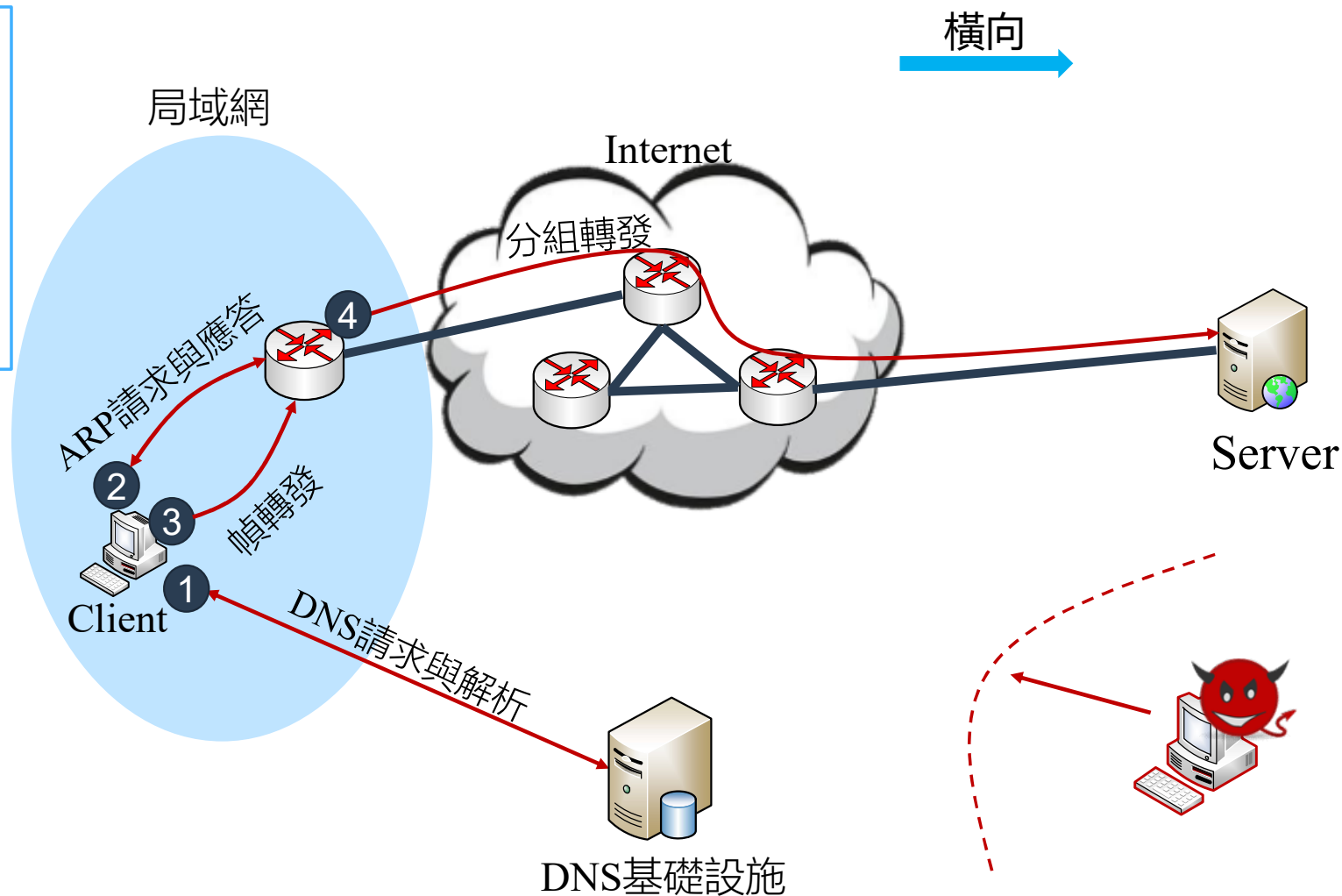




協議棧中消息的橫向傳遞

局域網中的Client遠程訪問Server時，在數據傳遞處理的每一步，都有可能產生安全問題

- 1 DNS劫持
- 2 ARP污染
- 3 嗅探監聽
- 4 地址偽造、路由劫持

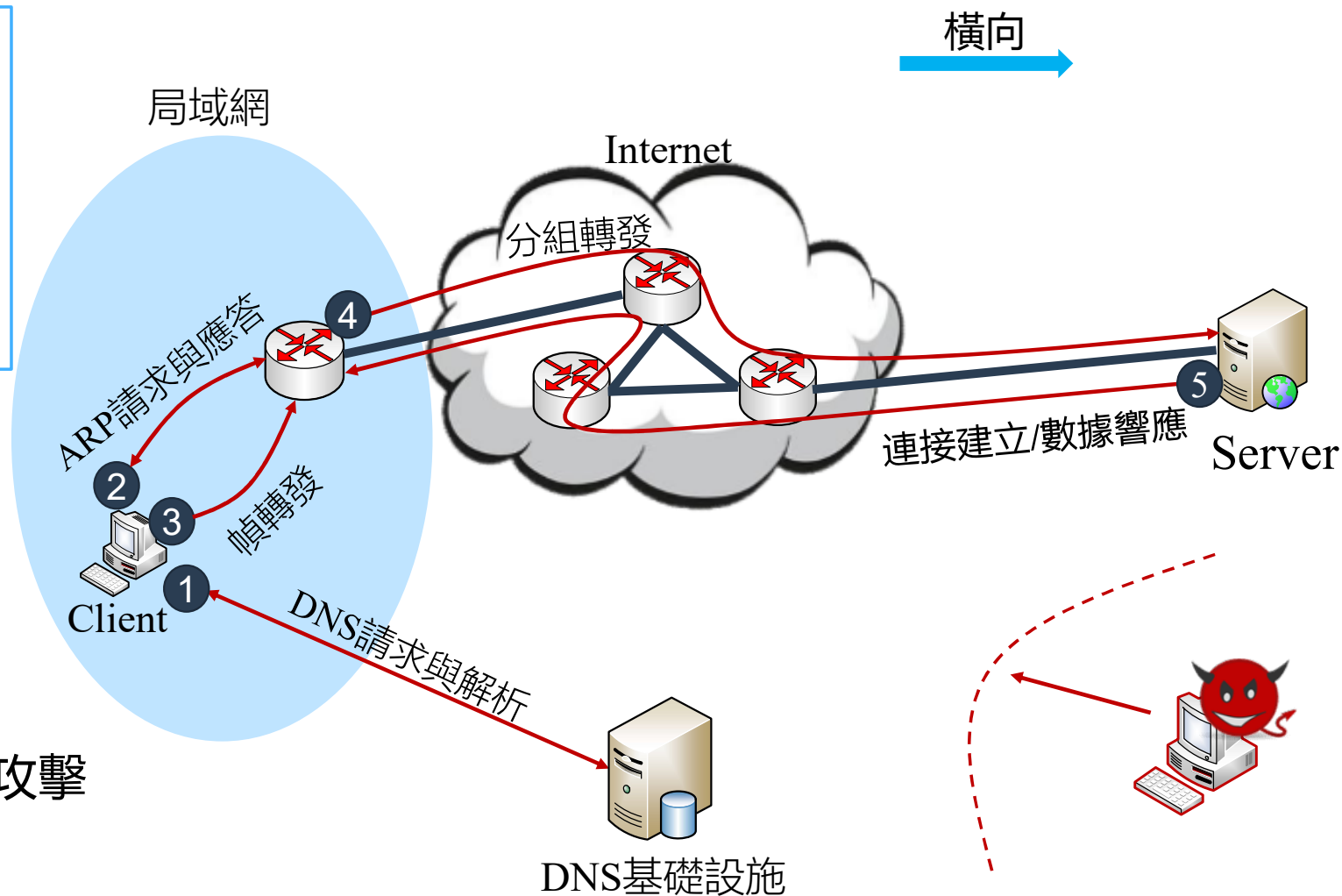




協議棧中消息的橫向傳遞

局域網中的Client遠程訪問Server時，在數據傳遞處理的每一步，都有可能產生安全問題

- 1 DNS劫持
- 2 ARP污染
- 3 嗅探監聽
- 4 地址偽造、路由劫持
- 5 TCP連接劫持、DoS攻擊





第2節 鏈路層安全

- ✓ 安全風險一：ARP欺騙與污染
- ✓ 安全風險二：網絡嗅探與網絡監聽



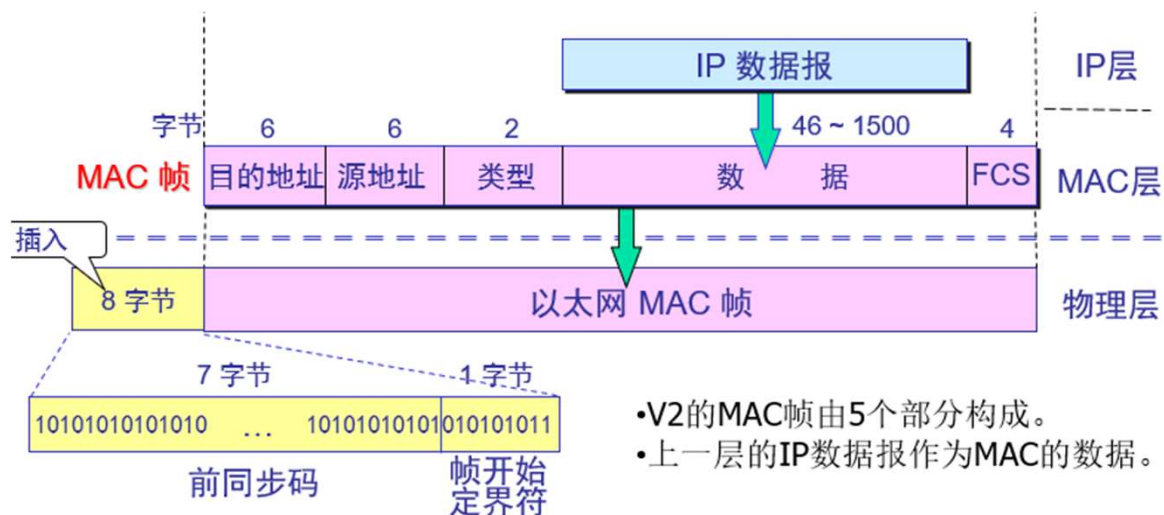
鏈路層功能



鏈路層最基本的功能是向該層用戶提供透明和可靠的數據傳送基本服務

主要功能有：

- 將數據組合成幀
- 控制幀在物理信道上的傳輸，包括處理傳輸差錯，調節發送速率
- 提供數據鏈路通路的建立、維持和釋放的管理

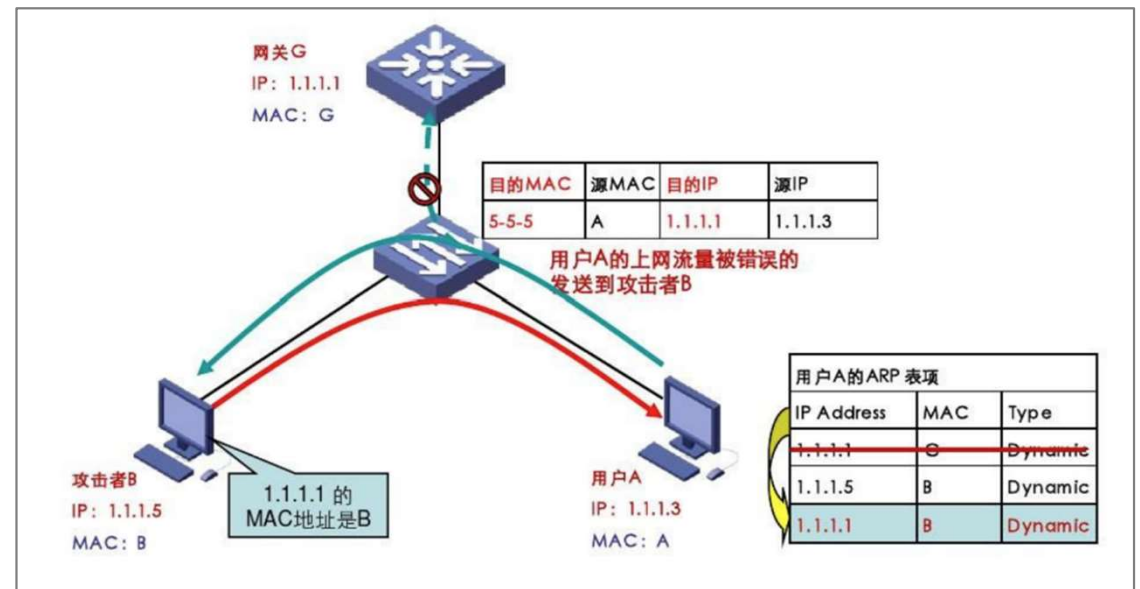
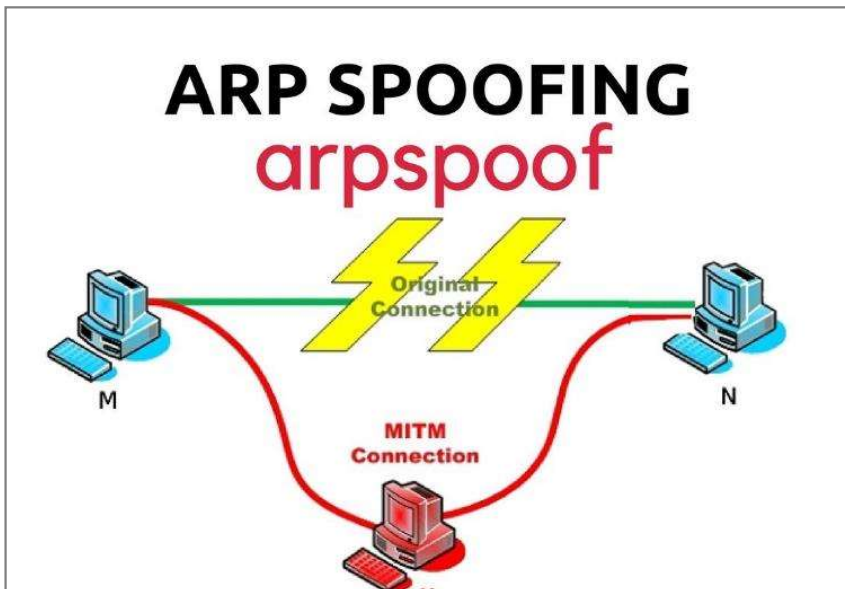


- V2的MAC帧由5个部分构成。
- 上一层的IP数据报作为MAC的数据。



ARP欺騙與污染

- ARP欺騙（ARP spoofing），又稱ARP污染（ARP poisoning），是針對以太網地址解析協議（ARP）的一種攻擊技術
- 可讓攻擊者成為中間人（Man-in-the-Middle, **MITM**），獲取局域網上的數據包，甚至可篡改數據包，同時迫使受害主機無法正常接收報文

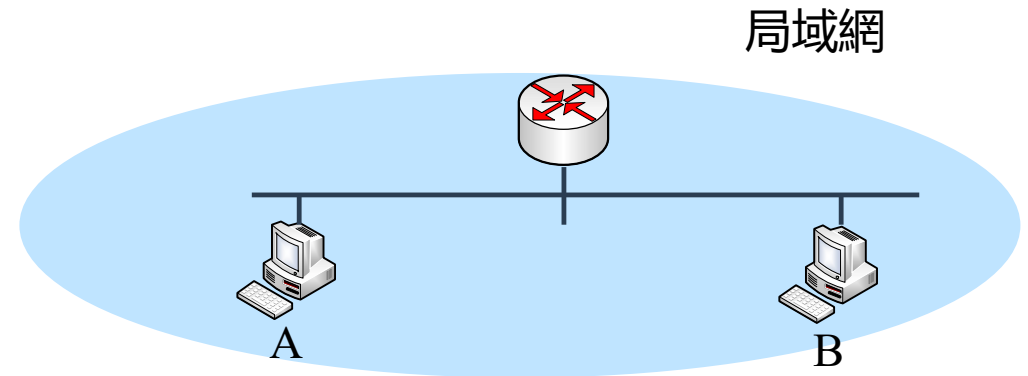




正常的ARP解析過程

拓撲示例：

局域網中的兩台主機A、B，以及他們的IP地址和MAC地址



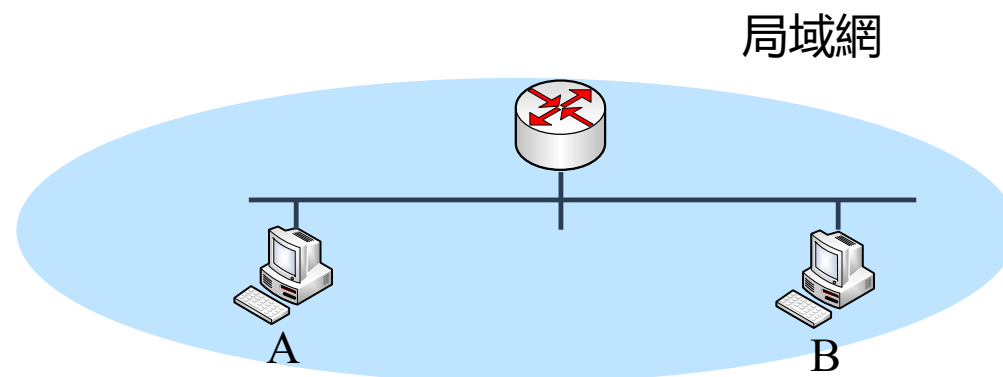
ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
	B	192.168.1.2	0A-11-22-33-44-02



正常的ARP解析過程

A、B間正常的ARP解析過程：

第1步： A主機在本地ARP緩存中，查找主機B的MAC地址



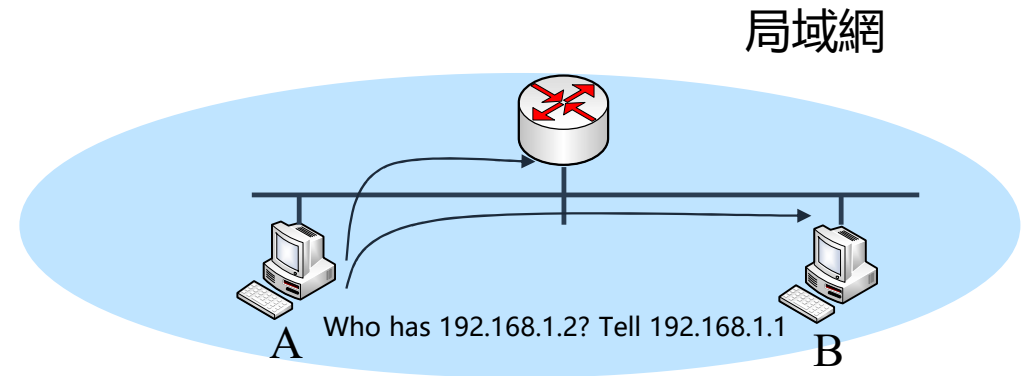
ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02



正常的ARP解析過程

A、B間正常的ARP解析過程：

第2步： 如果沒有找到，就需要通過將ARP請求幀廣播到本地網絡上的所有主機來詢問192.168.1.2的MAC地址



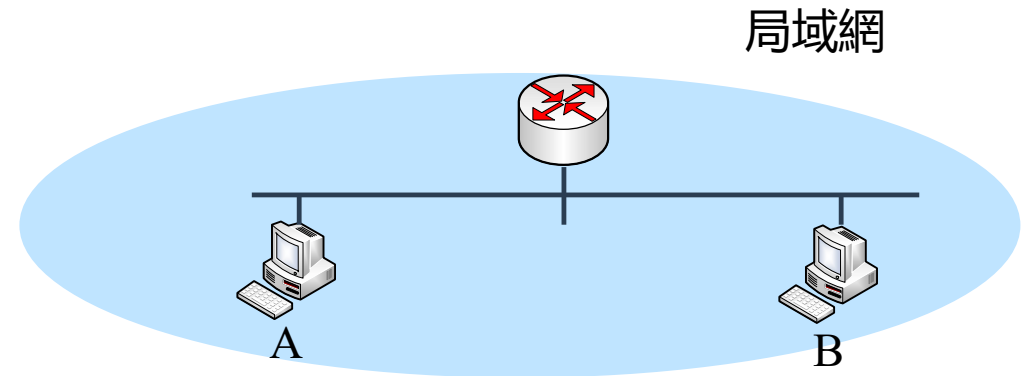
ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02



正常的ARP解析過程

A、B間正常的ARP解析過程：

第3步： 主機B確定ARP請求中的IP地址與自己的IP地址匹配，將主機A的IP地址和MAC地址映射添加到本地ARP緩存中



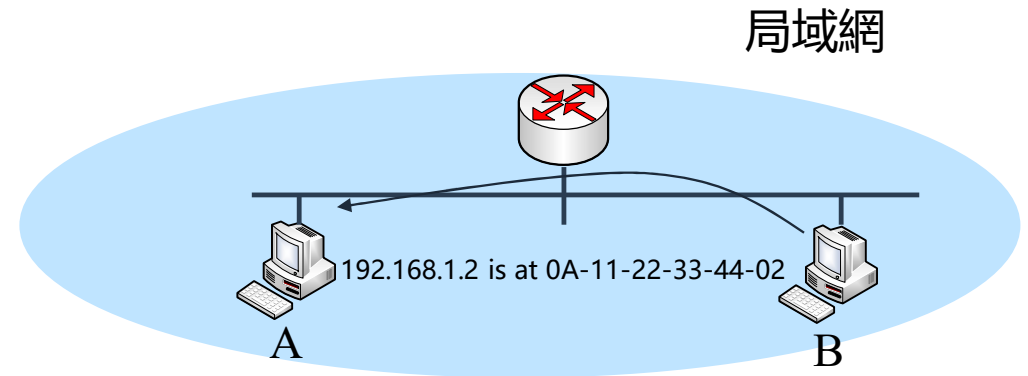
ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01



正常的ARP解析過程

A、B間正常的ARP解析過程：

第4步：主機B將包含其MAC地址的ARP回復消息，直接發送回主機A



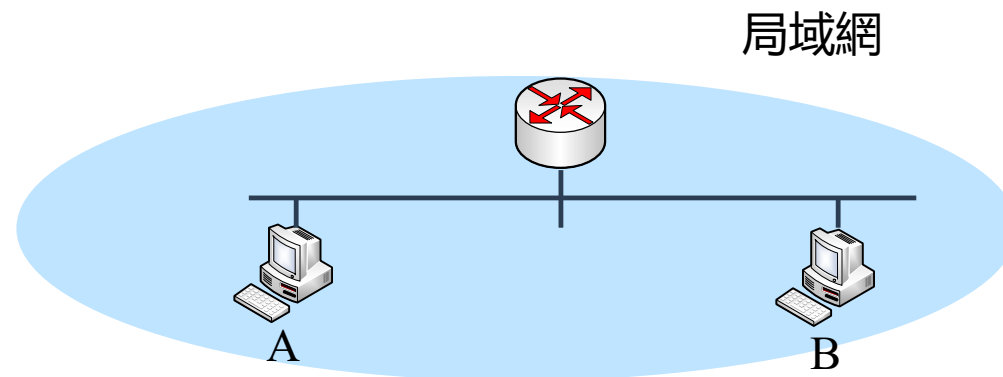
ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01



正常的ARP解析過程

A、B間正常的ARP解析過程：

第5步： A收到回復，用主機B的IP地址和MAC地址映射更新ARP緩存



ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	0A-11-22-33-44-02
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01



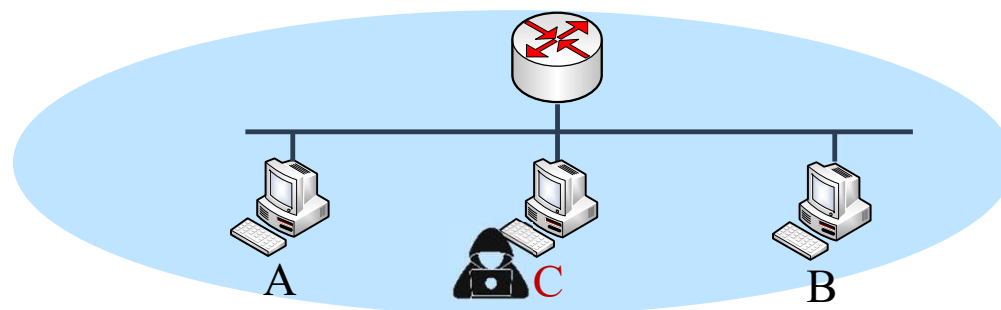
ARP欺騙與污染

安全問題：

在ARP回復時，主機A并
不會驗證ARP回復包的**真
實性**。由此引出一個局域
網攻擊方式

ARP欺騙：惡意主機C，
企圖冒充B，欺騙A

局域網



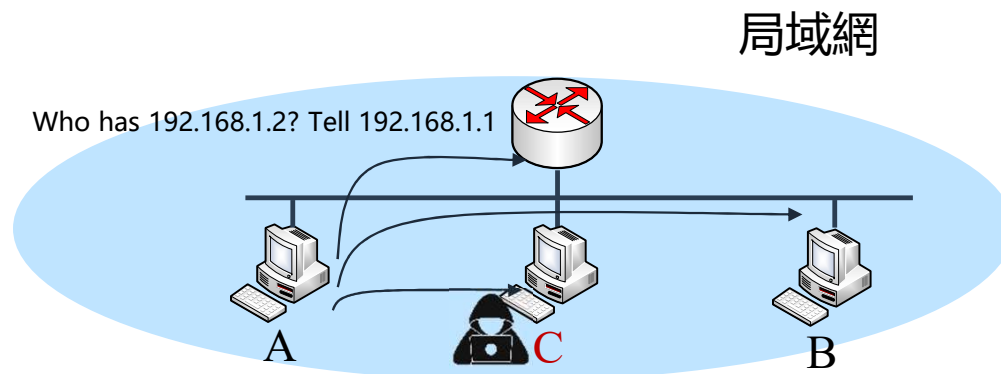
ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
	B	192.168.1.2	0A-11-22-33-44-02
	C	192.168.1.3	0A-11-22-33-44-03



ARP欺騙與污染

**惡意節點C進行ARP欺騙，
污染攻擊A的ARP緩存：**

第1步：主機A要和主機B
通信，主機A發出ARP包詢
問誰是192.168.1.2？請回
復192.168.1.1



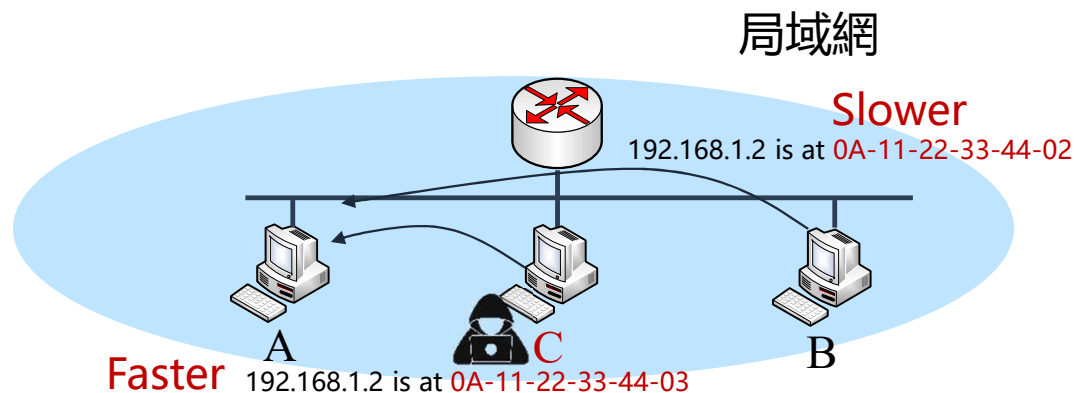
ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
	C	192.168.1.3	0A-11-22-33-44-03



ARP欺騙與污染

**惡意節點C進行ARP欺騙，
污染攻擊A的ARP緩存：**

第2步：主機C向主機A發送ARP應答報文，我是192.168.1.2，我的地址是0A-11-22-33-44-03

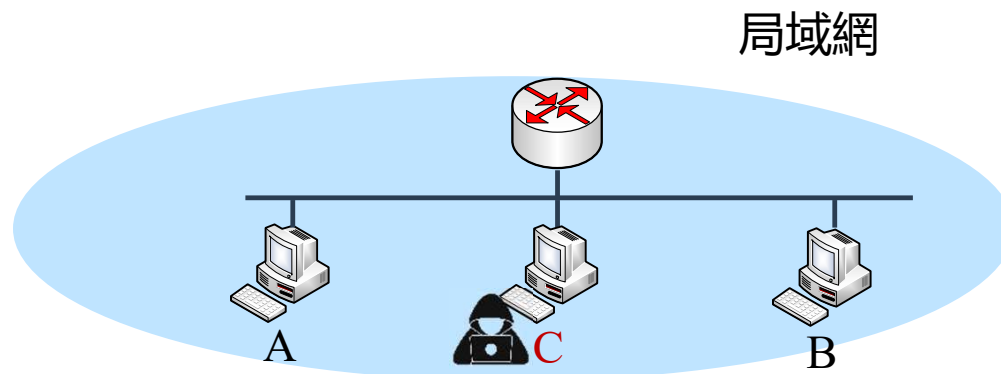


ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	?
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01
	C	192.168.1.3	0A-11-22-33-44-03



ARP欺騙與污染

**惡意節點C進行ARP欺騙，
污染攻擊A的ARP緩存：**
第3步： 當A收到C發來的
ARP回復消息時，會用**B的
IP地址和C的MAC地址**映
射，更新ARP緩存，從而
實現了攻擊者C對A發往B
的流量的劫持

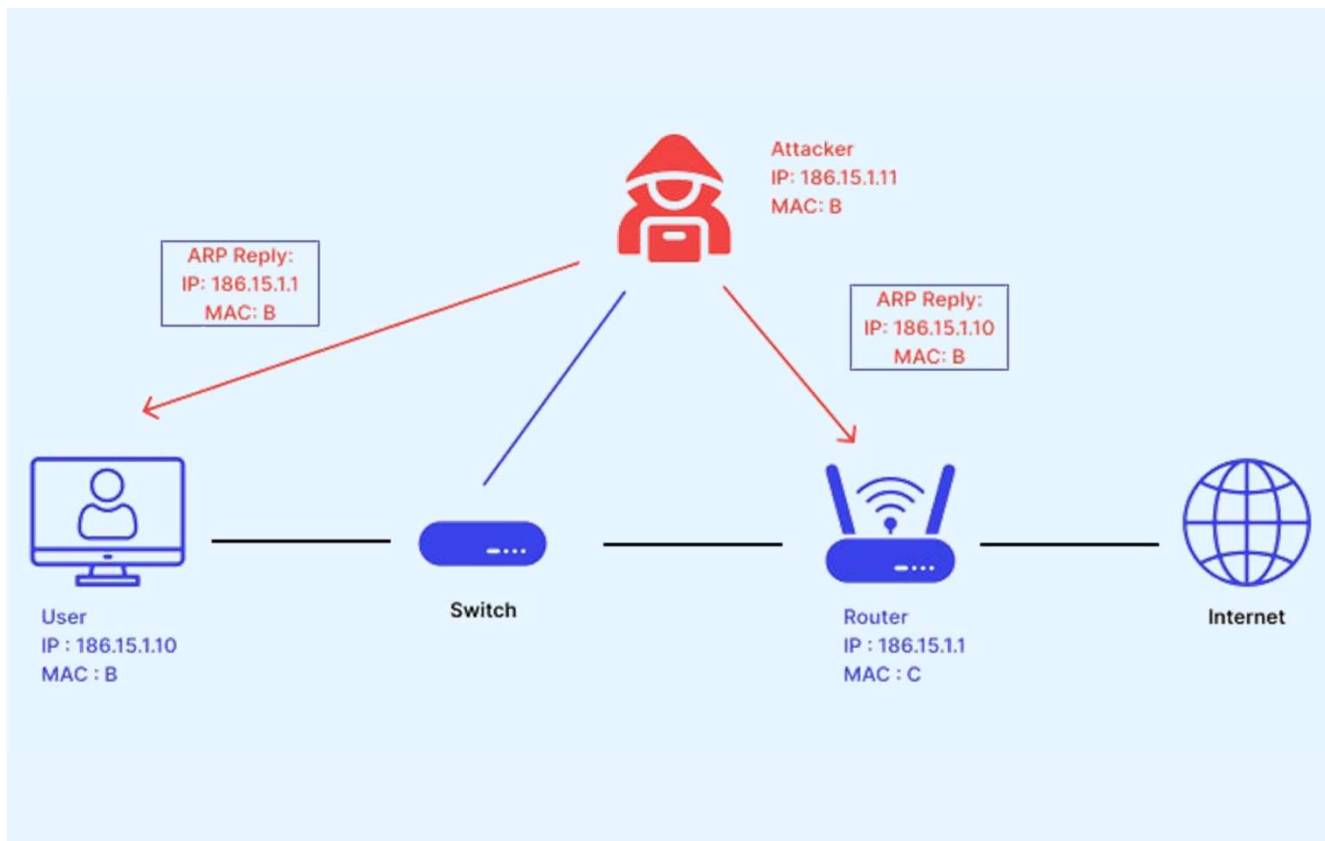


ARP 表	主機	IP	MAC
	A	192.168.1.1	0A-11-22-33-44-01
		192.168.1.2	0A-11-22-33-44-03
	B	192.168.1.2	0A-11-22-33-44-02
		192.168.1.1	0A-11-22-33-44-01
	C	192.168.1.3	0A-11-22-33-44-03



ARP欺騙與污染

如果攻擊者**假冒為網關**向受害者發送ARP廣播應答，從而成為中間人（Man-in-the-Middle, **MITM**），可以竊取或篡改局域網上的數據包，**危害更大**





如何防禦ARP欺騙與污染攻擊

靜態ARP綁定

將**IP地址和MAC地址綁定**在一起，防止ARP表被攻擊者篡改。
這種方法需要在網絡中的每個設備上**手動配置**

ARP監控

通過**實時監控ARP表的變化**，及時發現并防範ARP欺騙攻擊。
常用的ARP監控工具包括ARPWatch、ArpON等

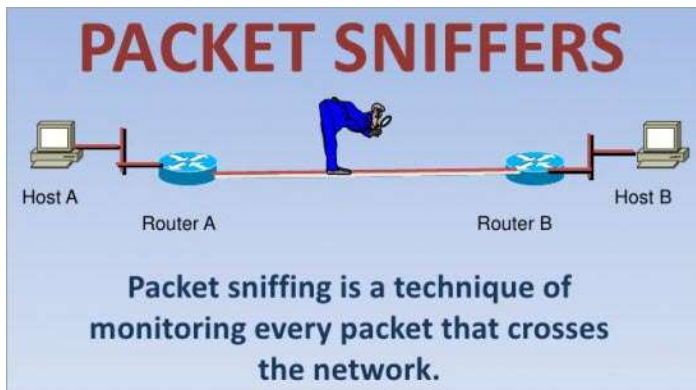
劃分虛擬局域網

將網絡分成多個虛擬的子網，不同的子網之間通過路由器連接。
這樣可以**將攻擊者與被攻擊設備隔離**開來，增加攻擊的難度



網絡監聽與嗅探

- 網絡嗅探 (Sniffers) 是一種網絡流量數據分析的手段，常見于網絡安全攻防技術使用，也有用于業務分析領域
- “嗅探工具”，也稱爲“數據包分析器”，還有別稱爲“嗅探器”、“抓包工具”等。常見的開源嗅探工具包括TCPDUMP, Wireshark等



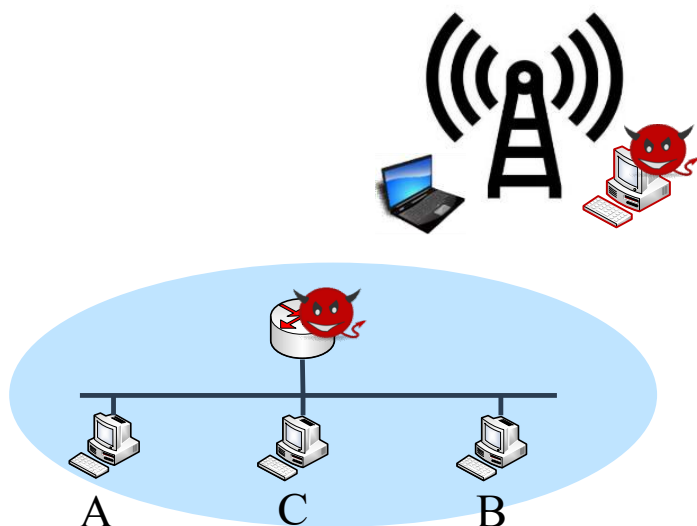
TCPDUMP





網絡嗅探具有兩面性

- **網絡管理員**使用嗅探器，通過捕獲分析網絡流量，進行高效的網絡管理
- **惡意攻擊者**使用嗅探器，攫取網絡中的大量敏感信息，進行網絡攻擊



惡意的網絡嗅探，取決於攻擊者的位置和攻擊能力：

- 共享網絡傳輸鏈路場景下，攻擊者的惡意嗅探監聽
- 攻擊者控制了網絡設備，對流經的流量進行攔截嗅探



“棱鏡” 計劃

2013年6月5日，前美國中央情報局雇員斯諾登向英國《衛報》和美國《華盛頓郵報》爆料，曝光了美國國家安全局（NSA）等美國政府部門監視公民隱私的“棱鏡（PRISM）”計劃，舉世嘩然



“棱鏡” 計劃監視範圍很廣

情報人員通過“後門”進入9家主要科技公司的服務器，包括微軟、雅虎、穀歌、Facebook、PalTalk、美國在綫、Skype、YouTube、蘋果



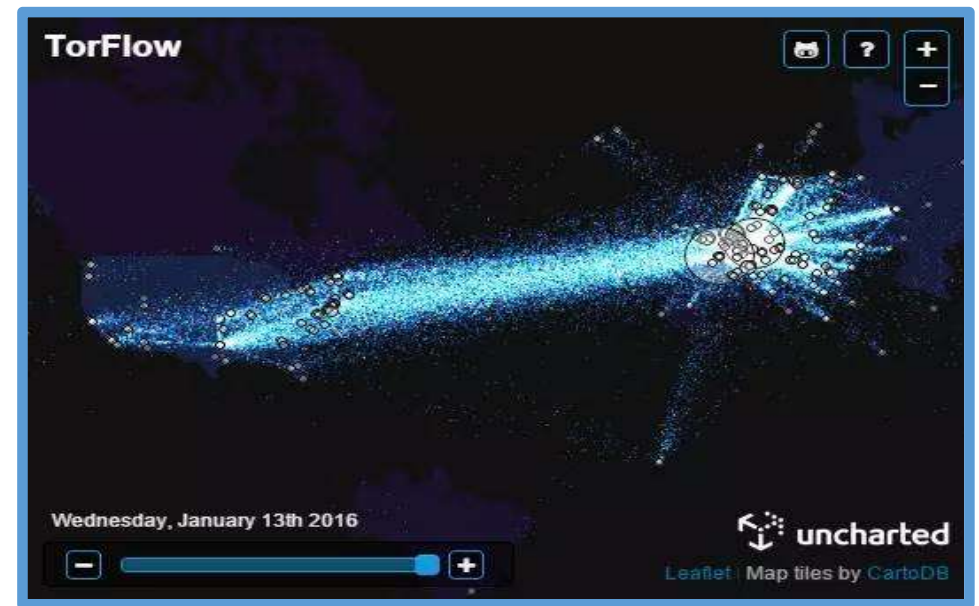


洋葱网络Torflow

2008年的節點數量



2016年的變化趨勢

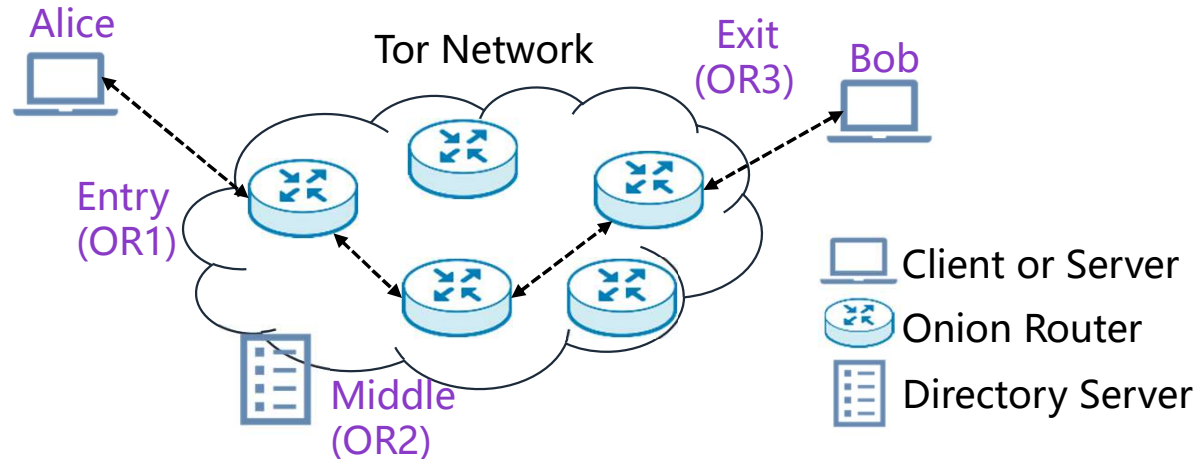


<http://torflow.uncharted.software/>

六年前，Tor匿名網絡還只有**2000**個主要節點，如今Tor網絡已經徹底去中心化并由分布于全球的**6425**個節點組成，每年下載Tor軟件的用戶近**5000萬**人次



洋葱网络工作原理

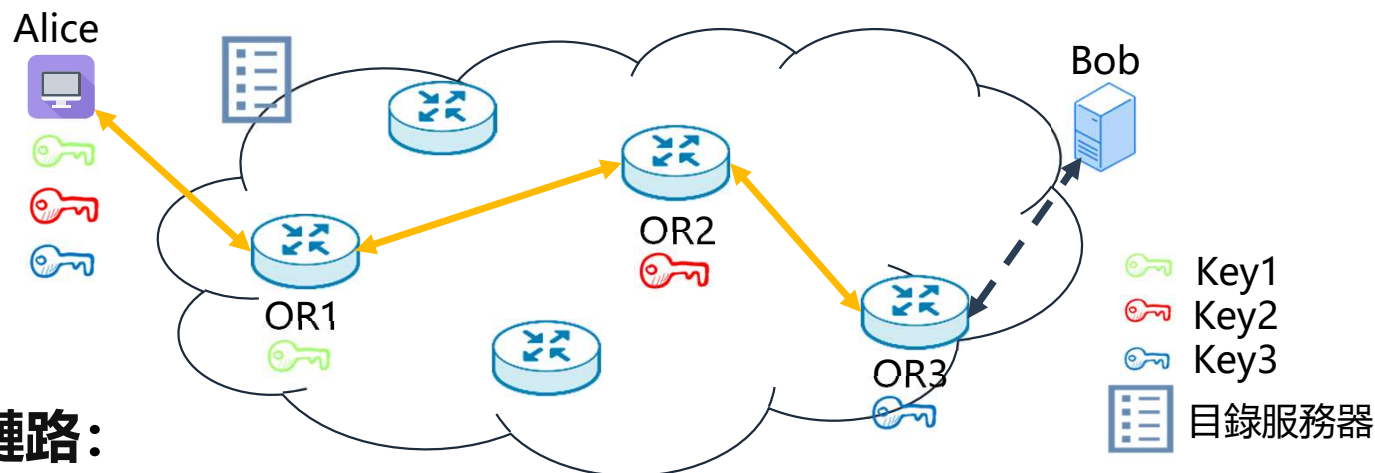


TOR的組成：

- 客戶端 (Client)：洋葱路由網絡的使用者
- 服務器 (Server)：TCP應用，如Web網頁
- 洋葱路由器 (Onion Router)：負責中轉數據包的路由器
- 目錄服務器 (Directory Server)：保存Tor網絡中所有洋葱路由器列表相關信息（洋葱路由器地址、公鑰等）



洋葱路由工作原理

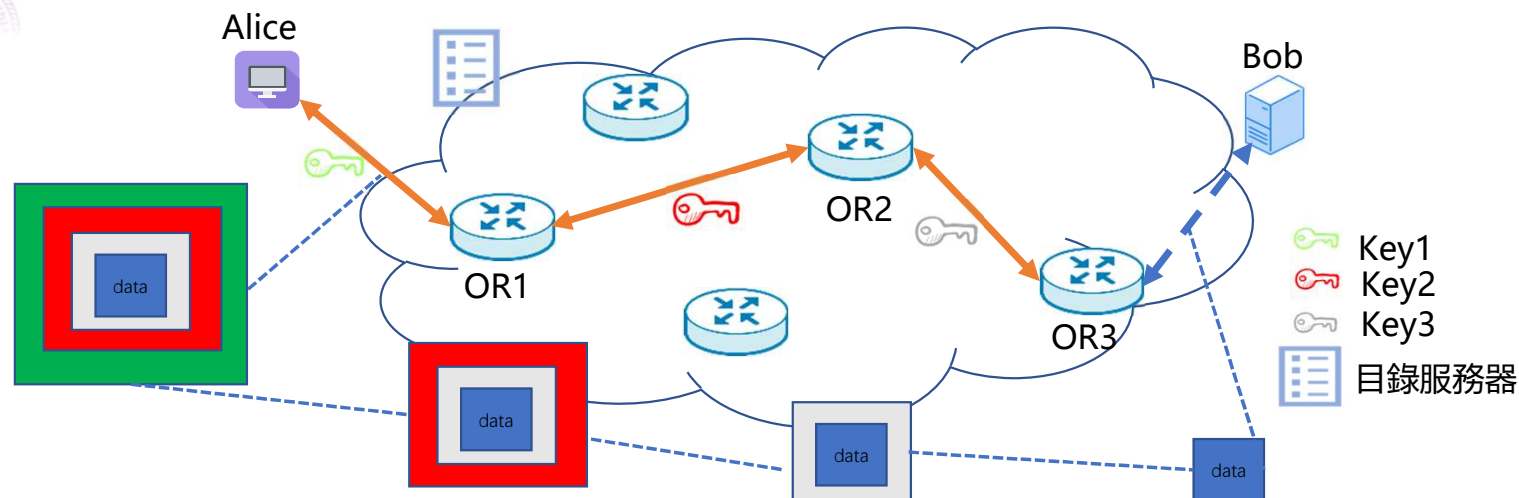


建立通信鏈路：

1. Alice從目錄服務器中隨機選取入口節點OR1
2. Alice和OR1通過Diffie-Hellman密鑰交換算法協商生成**對稱密鑰key1**
3. Alice從目錄服務器中選擇中間節點OR2，并向OR1用key1加密發送OR2的地址
4. OR1使用key1解開數據包，與OR2建立連接，使得Alice和OR2通過Diffie-Hellman算法協商出**對稱密鑰key2**（注意：OR2只知道消息來自于OR1，而不知道Alice的身份信息）
5. Alice重複步驟3、4，建立OR2與OR3之間的通信鏈路，并與OR3協商出**對稱密鑰key3**
6. 至此，Alice與3個中間代理的鏈路建立成功，擁有3把密鑰：**key1、key2、key3**



洋葱路由工作原理



爲了加強安全性，Tor
每隔十分鐘就會再重新
選擇三個節點以規避流
量分析和蜜罐節點

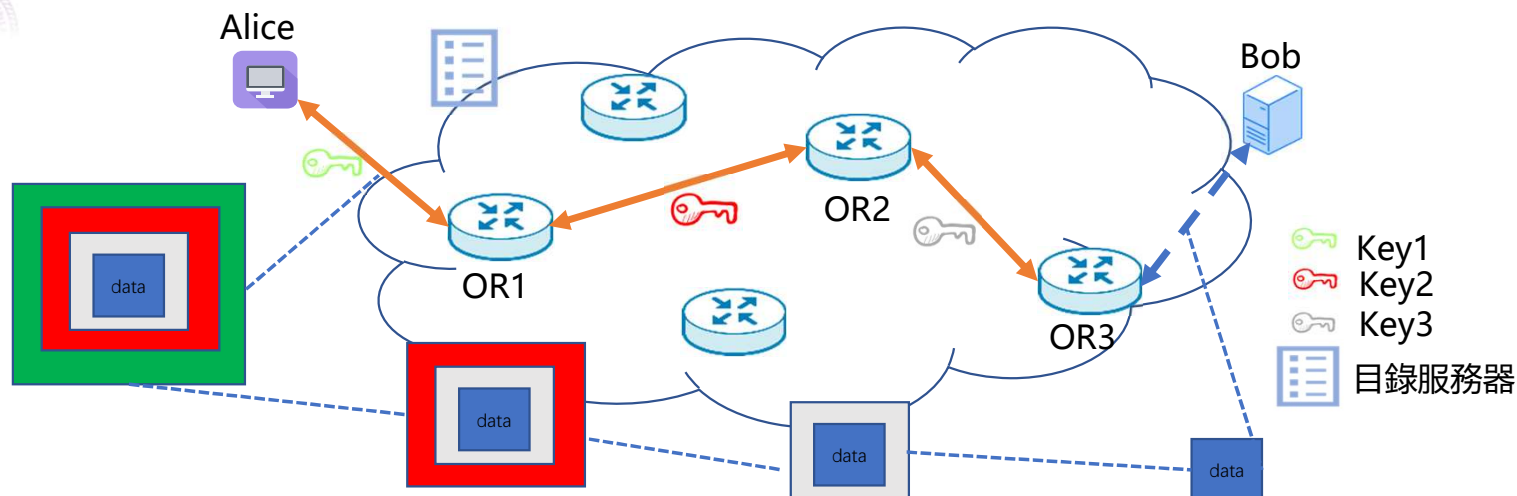
發送數據包：

1. Alice將要發送的數據（data）經過**3層加密包裹**：key1(key2(key3(data)))
2. OR1收到Alice數據包後使用**key1解密**，發現目的地是OR2，就將解開後的包發給OR2
3. OR2收到OR1發來的數據包用**key2重複解密**步驟：將接收的數據包解開發往OR3
4. OR3收到後使用**key3解密**，將data路由給Bob

只有入口節點知道用戶真實IP地址，只有出口節點知道用戶的目的地和傳輸內容



洋葱路由安全風險



1. OR3到Bob的流量是**明文**
2. 網頁指紋分析：每個網頁的布局和JavaScript代碼、圖片、視頻、廣告等元素不完全相同，訪問過程中產生的**網絡流量就有區別**，例如數據包的大小、順序和時間等非敏感信息可以形成**網頁指紋**(Webpage fingerprinting, WF)

基本上來說，運營商還是能知道用戶正在使用Tor瀏覽器



混淆暗網流量識別問題

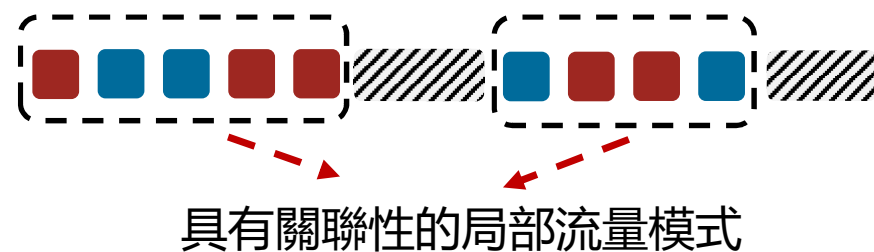
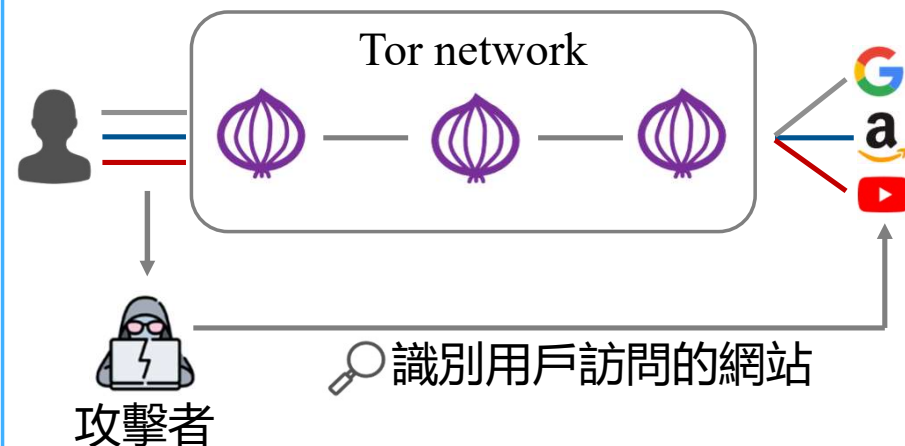
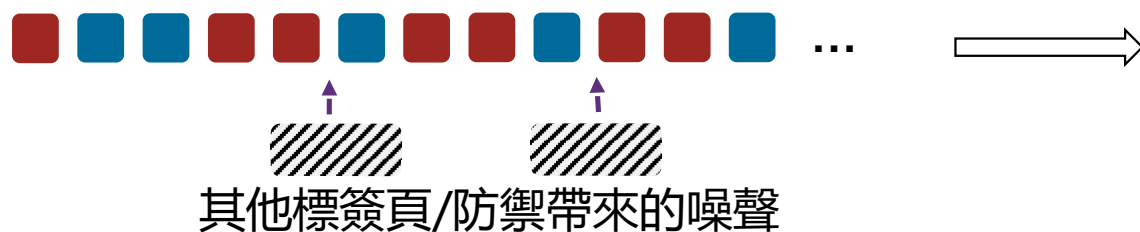
網站指紋攻擊

- 攻擊者提前搜集不同網站的暗網流量訓練模型
- 將未知流量輸入到模型，識別用戶訪問的網站

研究問題：多標籤頁網站指紋攻擊

- 分析Tor用戶多標籤頁并發訪問的混淆暗網流量，識別用戶同時訪問的多個網站

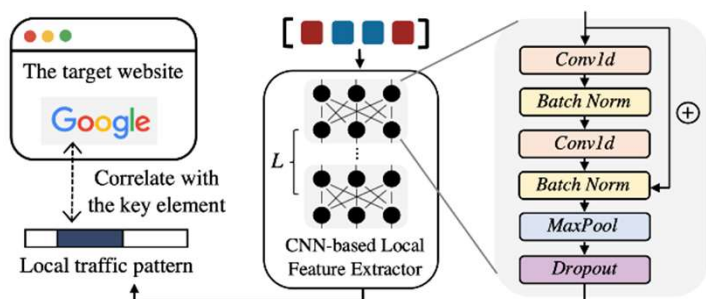
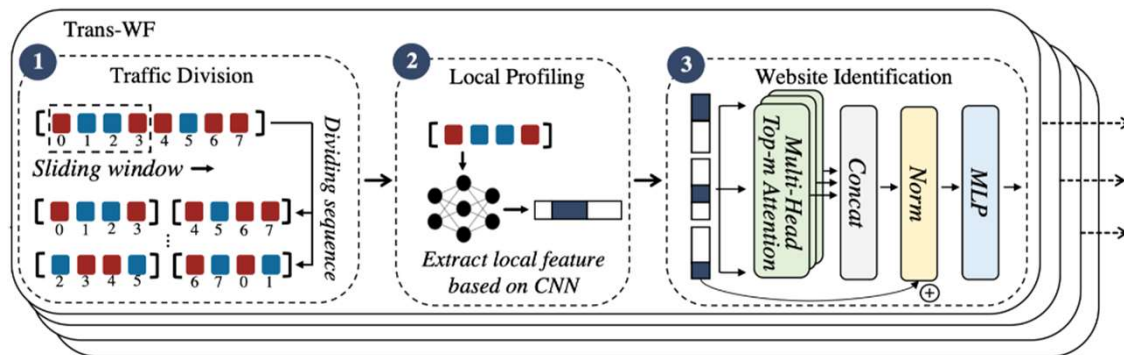
關鍵發現： 混淆流量的局部保留了目標暗網的關鍵流量模式



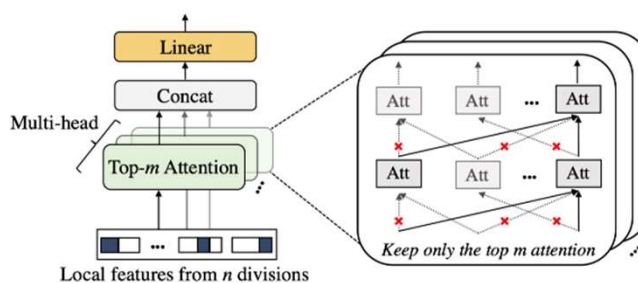


ARES: 魯棒的多標籤頁網站指紋攻擊

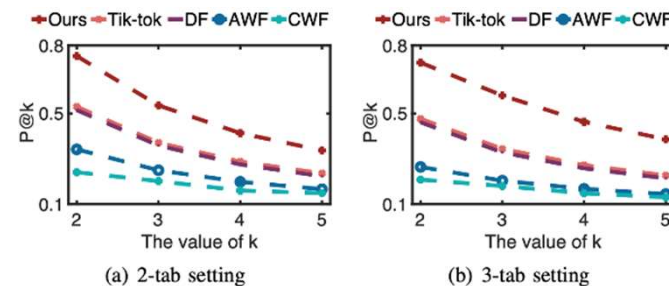
核心思路：集成多個分類器，利用CNN提取局部指紋模式，并基于魯棒的m-attention機制分析局部指紋關聯性以識別網站



利用平移不變性提取局部流量特徵



魯棒的自注意力機制設計



真實世界搜集的暗網流量實驗

利用真實世界的暗網流量進行評估，本研究實現最優的F1-Score 91.4%，
相比基準方法平均提升 132.6%

[1] Robust Multi-tab Website Fingerprinting Attacks in the Wild. IEEE S&P 2023.



第3節 網絡層安全



安全風險一：源地址假冒攻擊



安全風險二：IP分片攻擊



安全風險三：ICMP攻擊



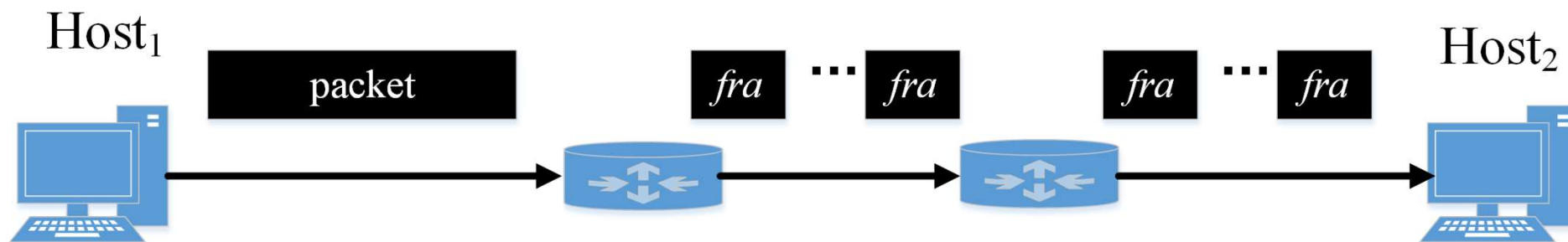
安全防禦一：IPSec協議



安全防禦二：網絡入侵檢測系統IDS



IP分片攻擊原理



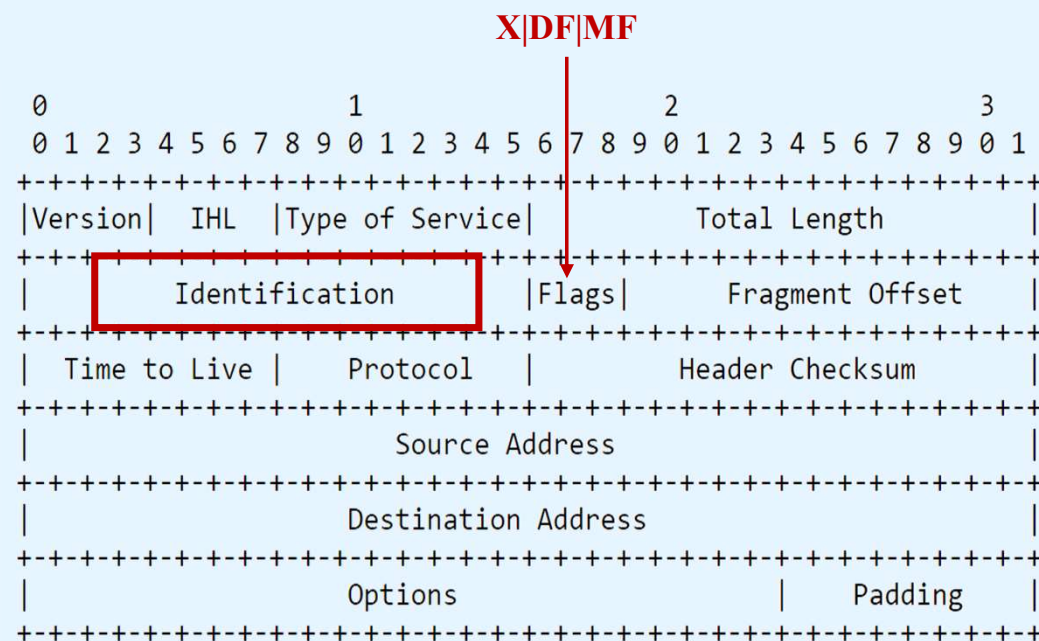
當互聯網上的兩台遠程主機進行數據傳輸時，如果傳輸路徑上的各路由器間，存在不同的鏈路**最大傳輸單元**（Maximum Transmission Unit, **MTU**），那麼可能會發生IP分組分片（IP fragmentation），以滿足鏈路MTU的要求



IP分片攻擊原理

所有的IP分片到達目的接收端後，接收端對這些分片進行**重組**，還原出原來的IP分組，再提交給上層進行處理

分片的重組依賴于**IPID字段**，而原始IP分組是否允許被分片，取決于Flags字段中DF位（為1表示不進行分片）



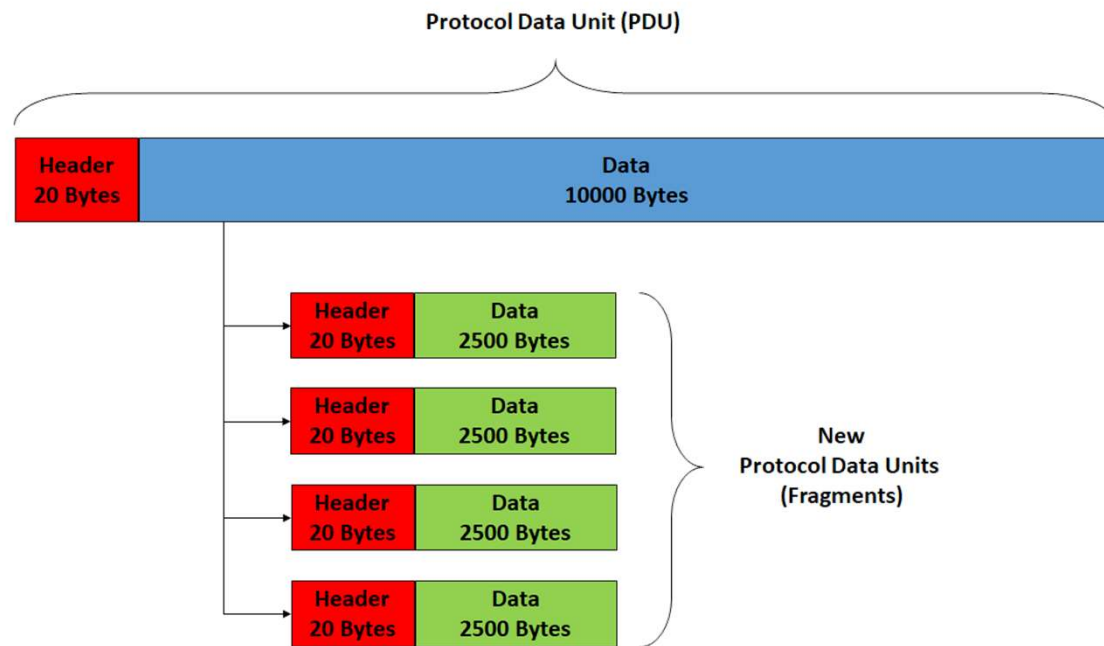


IP分片攻擊原理

IP分組的這種先分片、再重組的機制，為攻擊者暴露出了IP層的一個攻擊面
分組的碎片化發生在**源主機或中間路由器**上，而重組往往都在目的接收端發生

根據不同的攻擊效果，IP分片攻擊
可以分為3種：

- 拒絕服務攻擊
- 污染攻擊
- 安全策略逃逸





IP分片利用—拒絕服務攻擊

理論上一個IP分組的最大長度是65535字節，攻擊者可以發送一個長度超過65535字節IP分組，迫使接收端在對分片重組時，出現**緩衝區溢出**漏洞，造成異常錯誤

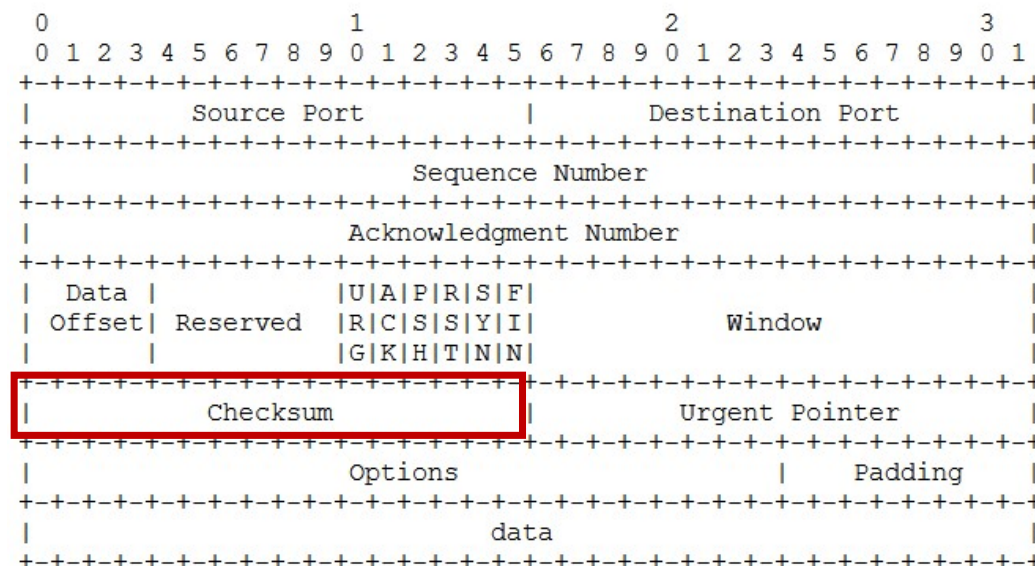
- **Ping of Death**: 攻擊者通過發送長度超過65535字節的Echo Request數據包給目標主機，該數據包經過中間路由器分片，然後到達目標主機
- 早期的一些TCP/IP協議棧實現（如Windows98之前的Windows操作系統），存在內存分配錯誤，會發生事先分配的65535字節**緩衝區溢出**，從而引起系統崩潰或挂起，造成拒絕服務攻擊





IP分片利用—拒絕服務攻擊

其他的利用IP分片進行DoS攻擊的技術：如**偽造分片和原始合法分片**錯誤重組，導致TCP或UDP報文的校驗和出錯，或者造成內存錯誤和系統崩潰（汨滴攻擊）



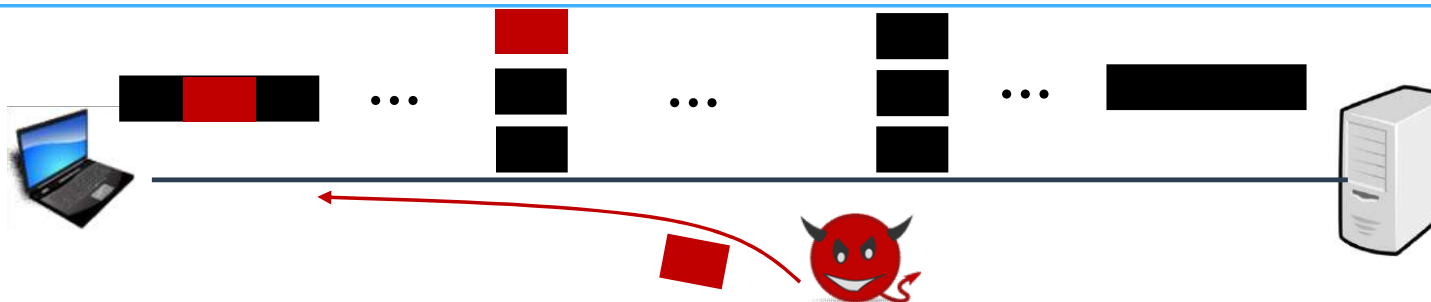
TCP Header Format

Note that one tick mark represents one bit position.



IP分片利用—污染攻擊

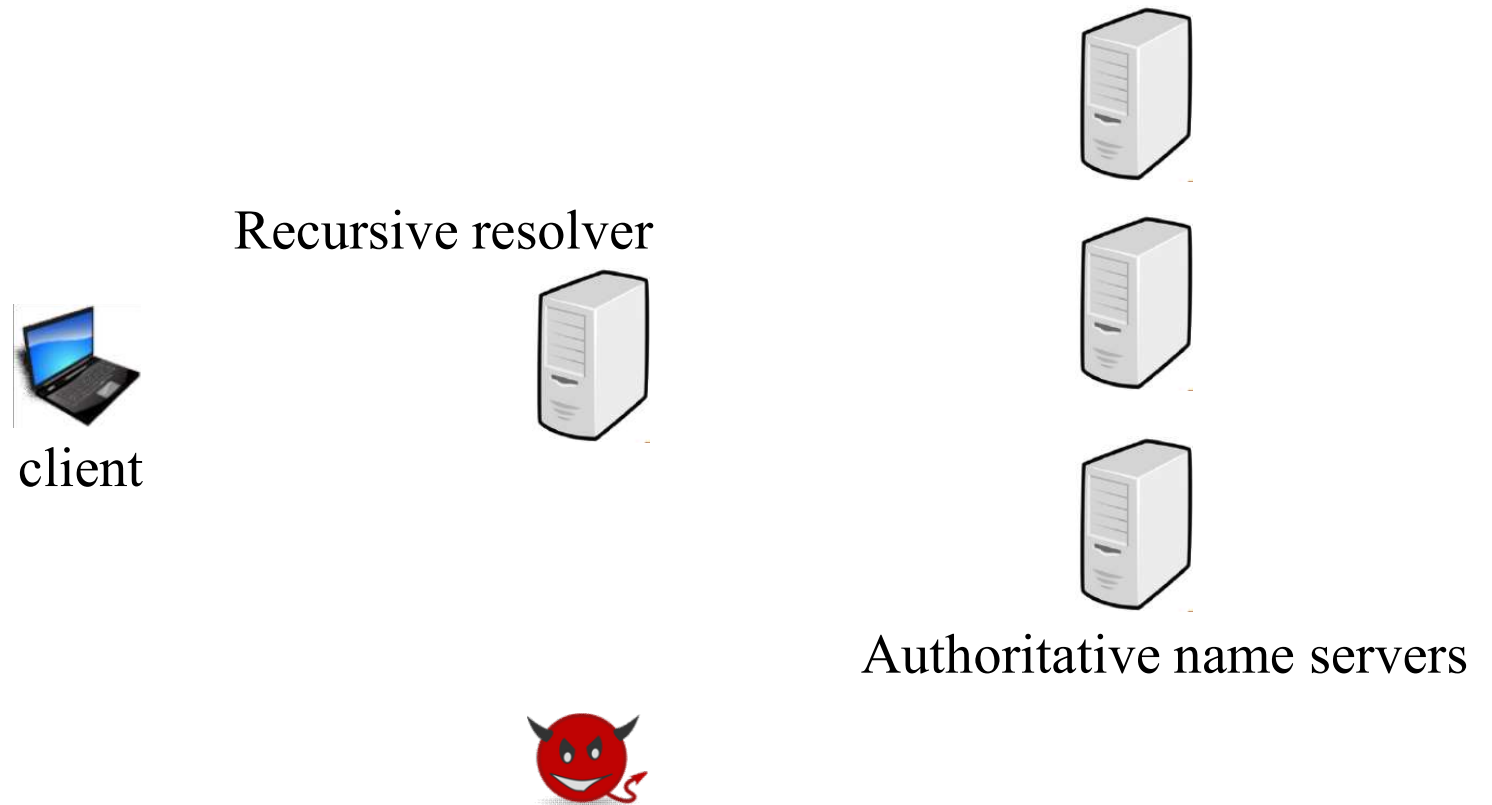
- 在原始報文被分片、傳輸過程中，攻擊者**偽造一些分片**，注入到正常分片流中，篡改原始報文內容，從而形成對合法流量的污染
- 在這一過程中，攻擊者需要具備的能力：
 - 源地址欺騙
 - IPID的猜測
 - 原始報文校驗和的欺騙等



基于分片的污染攻擊技術，已被廣泛應用到DNS緩存污染、流量攔截等場景中

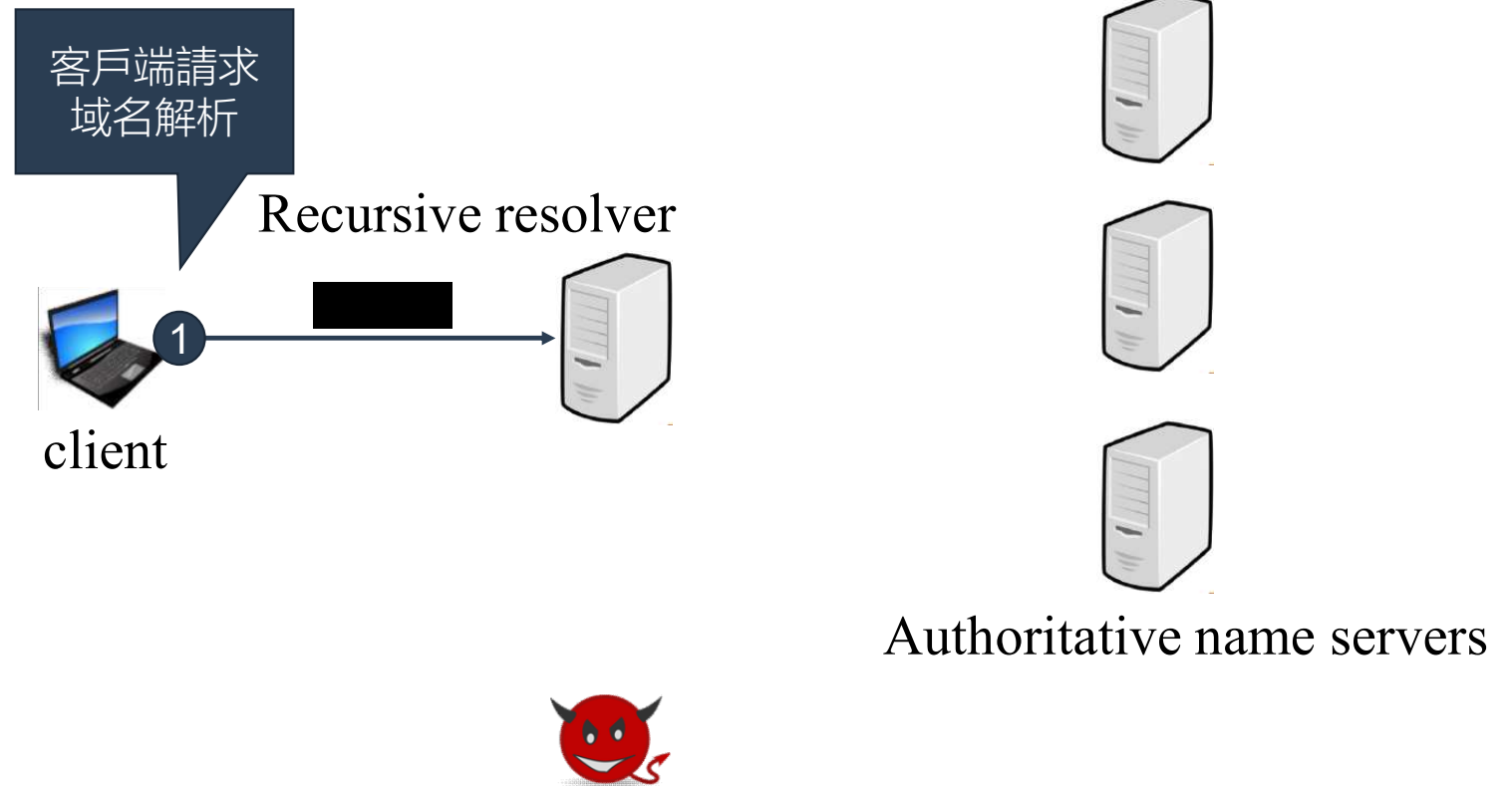


IP分片利用—基于IP分片的DNS缓存污染攻击



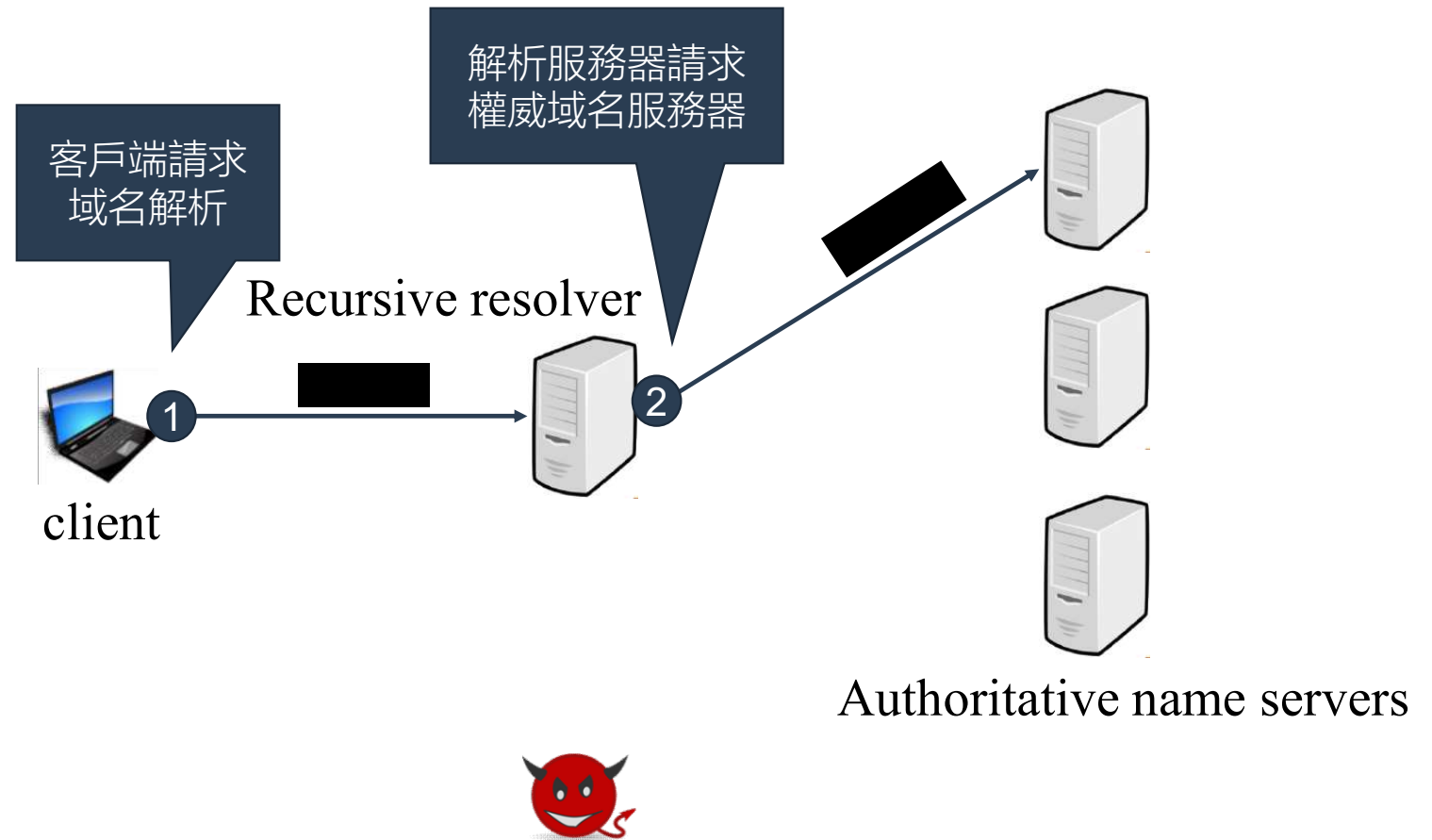


IP分片利用—基于IP分片的DNS緩存污染攻擊



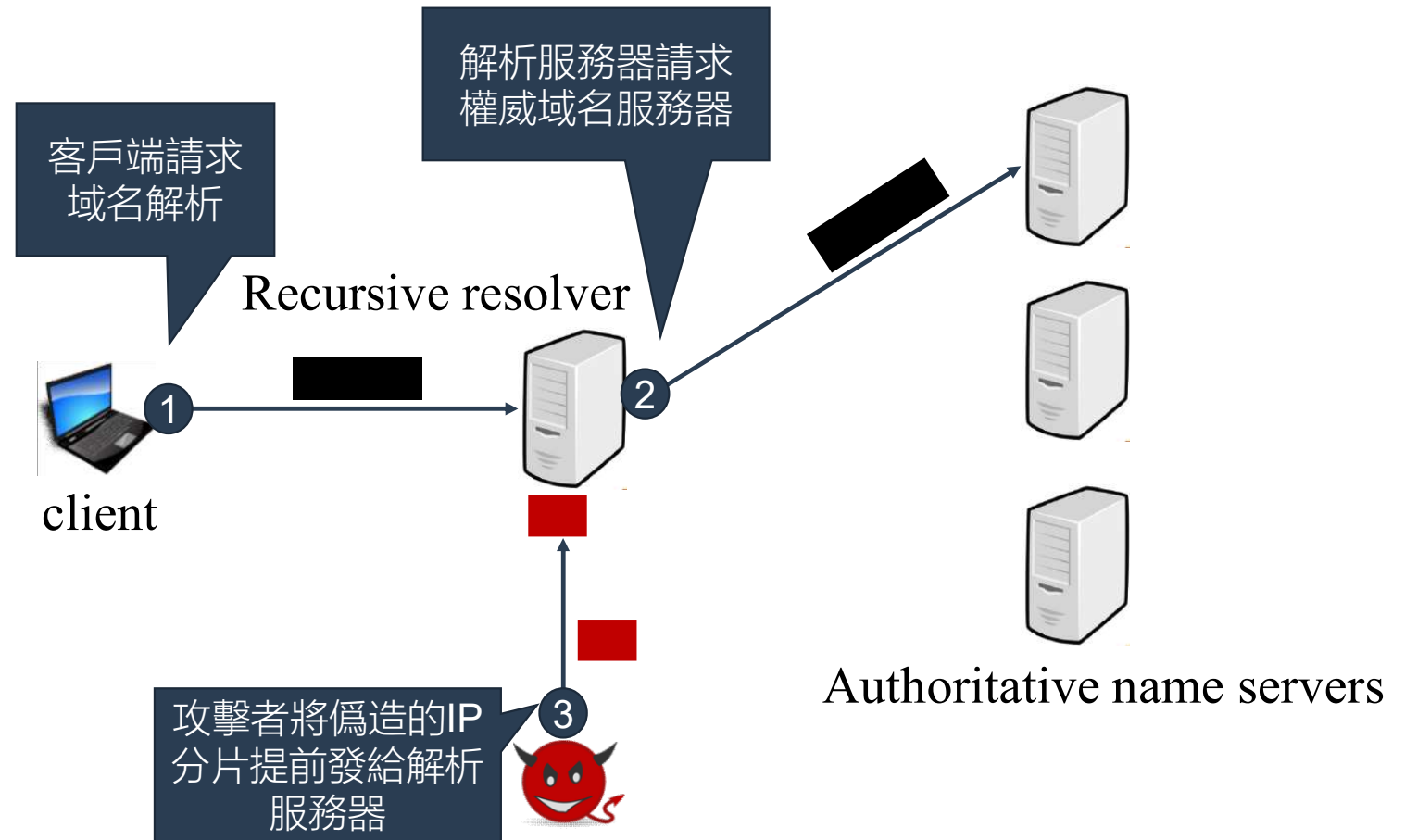


IP分片利用—基于IP分片的DNS緩存污染攻擊



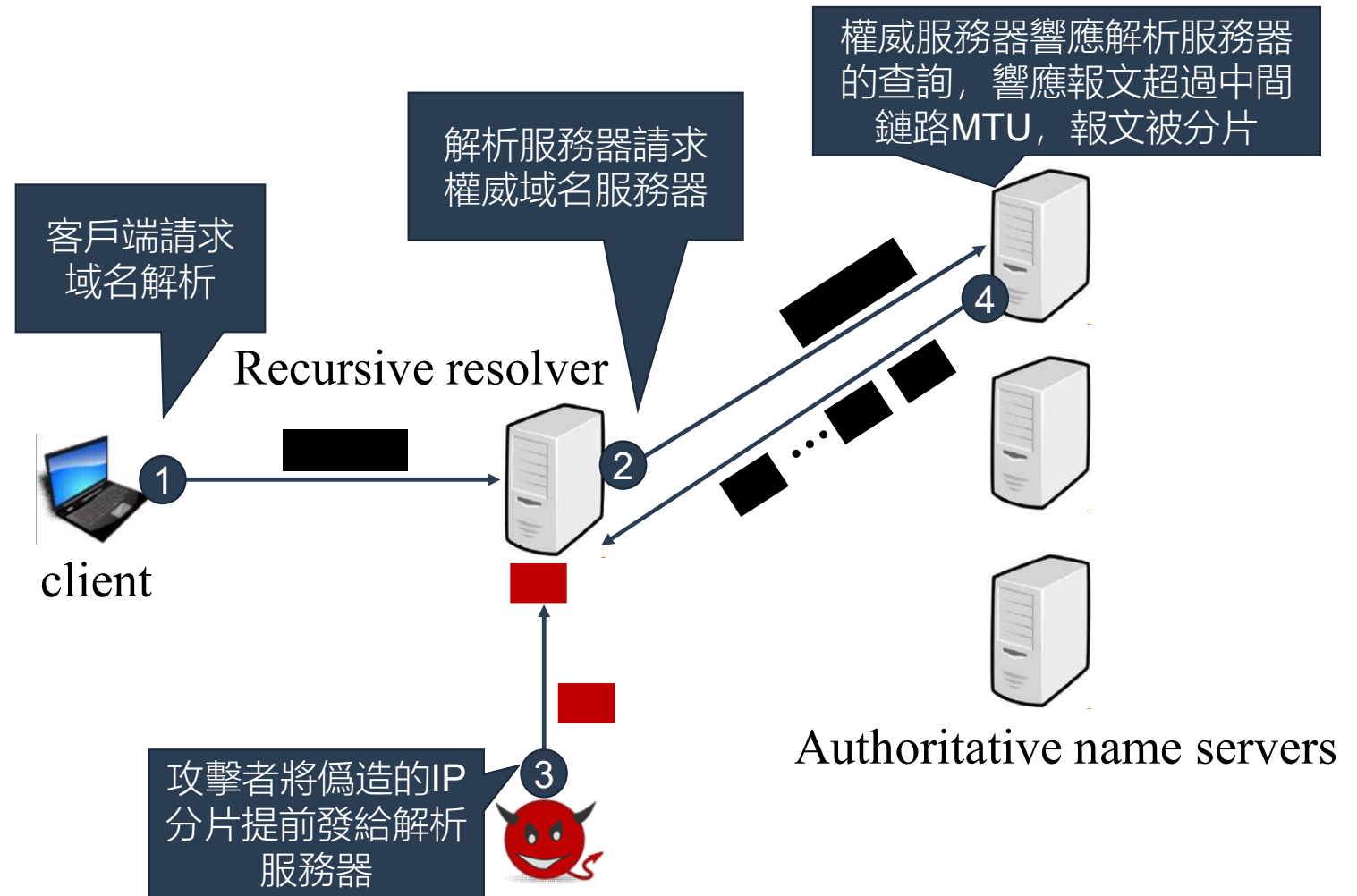


IP分片利用—基于IP分片的DNS緩存污染攻擊



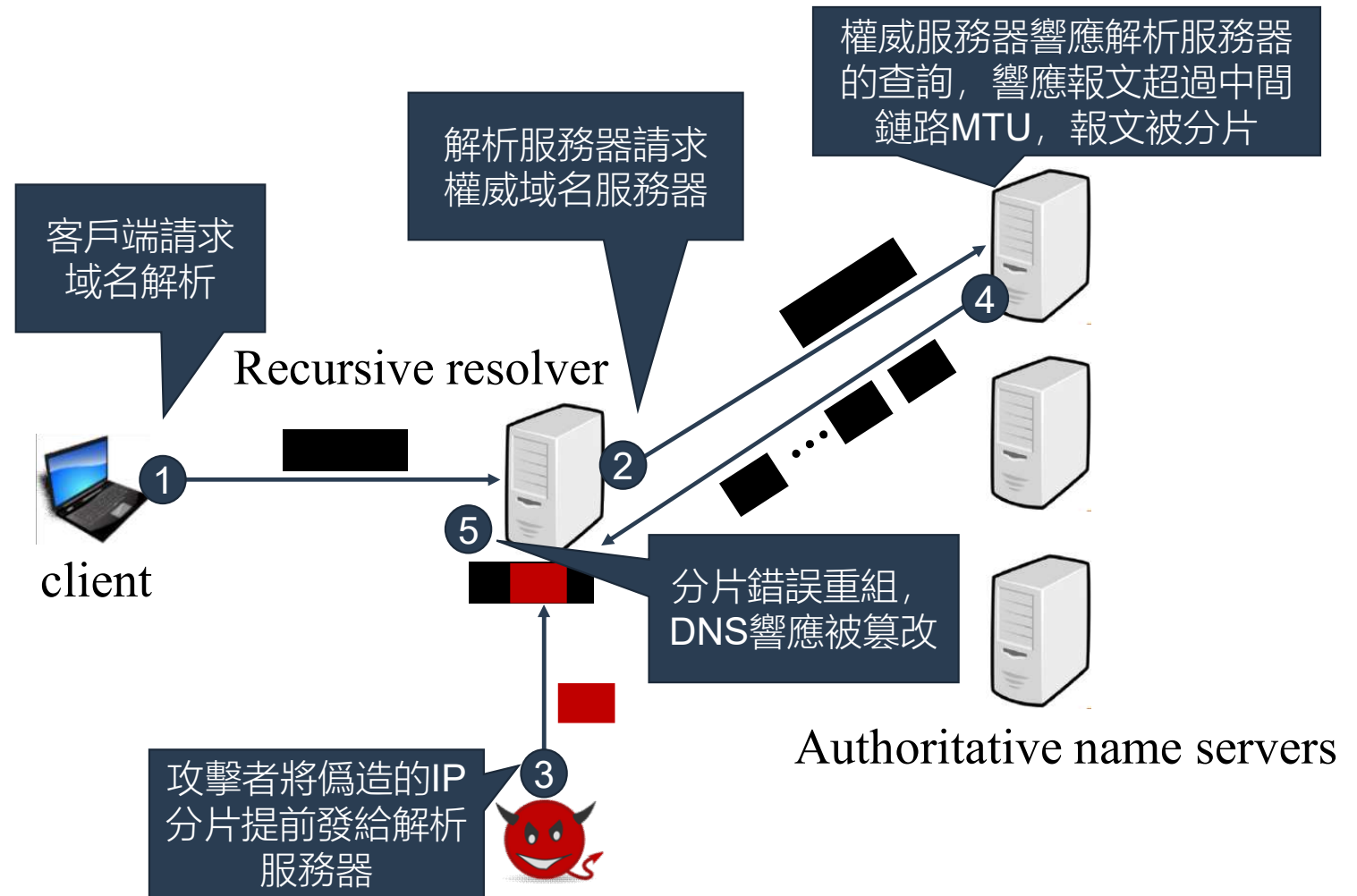


IP分片利用—基于IP分片的DNS緩存污染攻擊



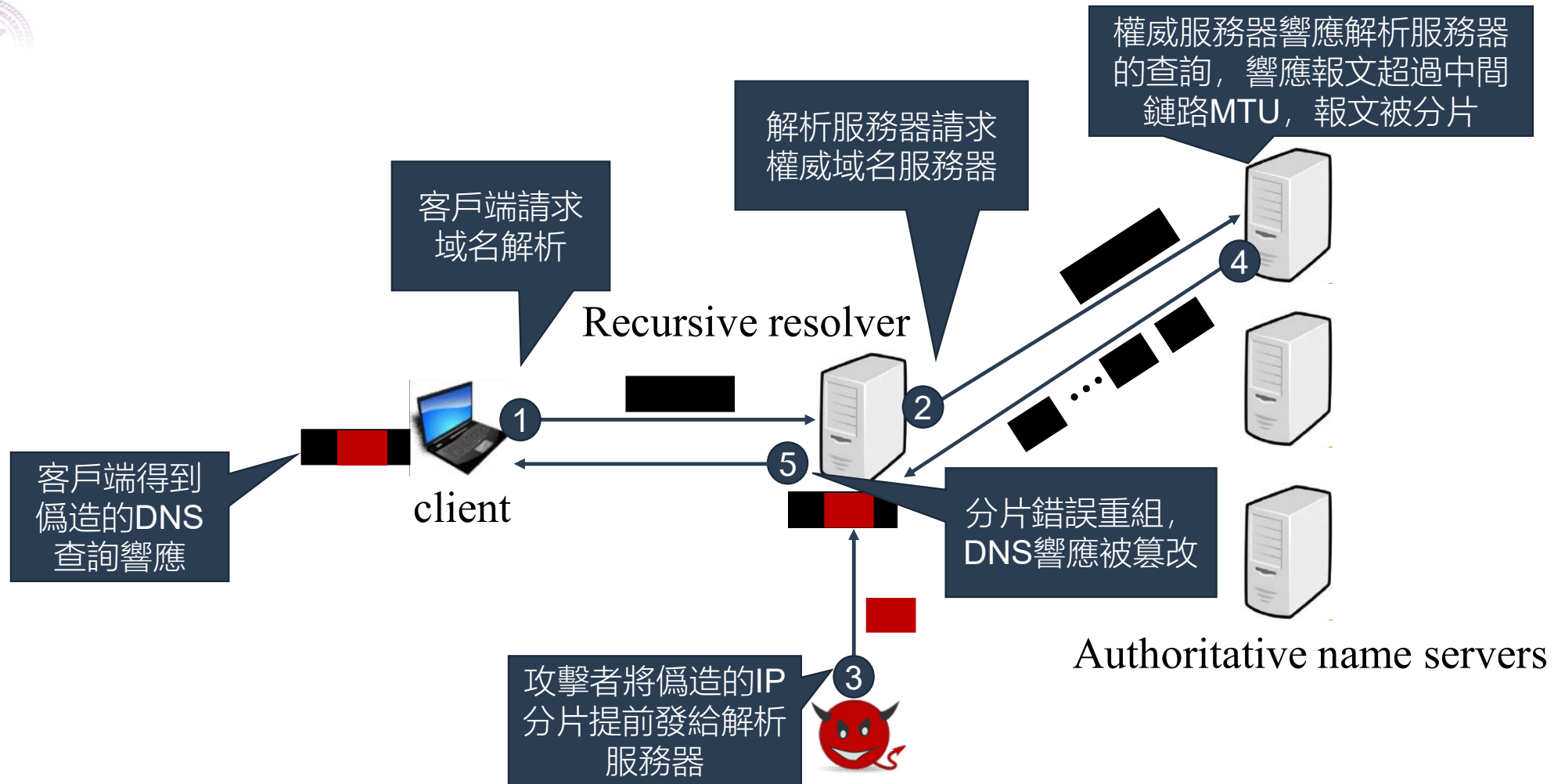


IP分片利用—基于IP分片的DNS緩存污染攻擊





IP分片利用—基于IP分片的DNS緩存污染攻擊





IP分片利用—基于IP分片的DNS緩存污染攻擊

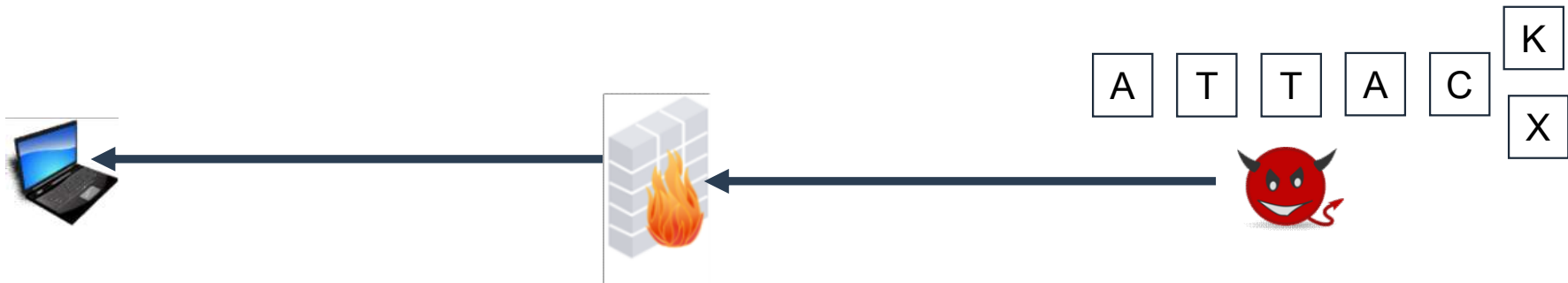
Offsets	Octet	0								1								2								3										
Octet	Bit	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31			
0	0	v4				IHL = 20				TOS								Total Length = 85																		
4	32	IPID = 23456																x	DF	MF	Frag Offset = 48															
8	64	TTL								Protocol = 17								IP Header Checksum																		
12	96	Source IP = 2.2.2.2																																		
16	128	Destination IP = 7.7.7.7																																		
20	160	Data Length = 4																IPv4 Address																		
24	192	6.6.6.6																Name = 0								Type										
28	224	= OPT								UDP Payload Size = 4096																EXTENDED-RCODE = 0										
32	256	Version = 0								DO	Z																Data Length									
36	288	= 0																																		

利用IP分片，將域名的合法IP地址，篡改成攻擊者控制的地址“6.6.6.6”，實現域名劫持



IP分片利用—安全策略逃逸

通常網絡防火牆會對IP分片進行虛擬分片重組，審查其中的惡意載荷。但防火牆和接收端主機往往存在**重組策略不一致**現象，即當分片出現重疊時，二者可能會採用不同的覆蓋策略

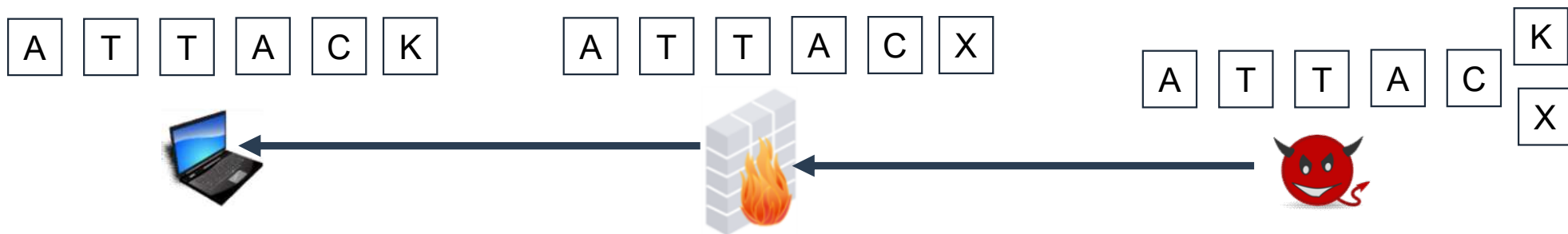




IP分片利用—安全策略逃逸

因此，攻擊者可以通過設置合理的分片偏移，逃逸防火牆的審查，形成對接收端的破壞

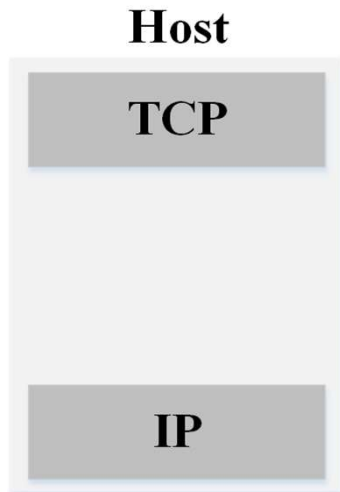
虛擬分配重組本身也可能被攻擊：例如，攻擊者長期不發送最後一個分片導致緩存資源被長期占用





路徑MTU發現機制

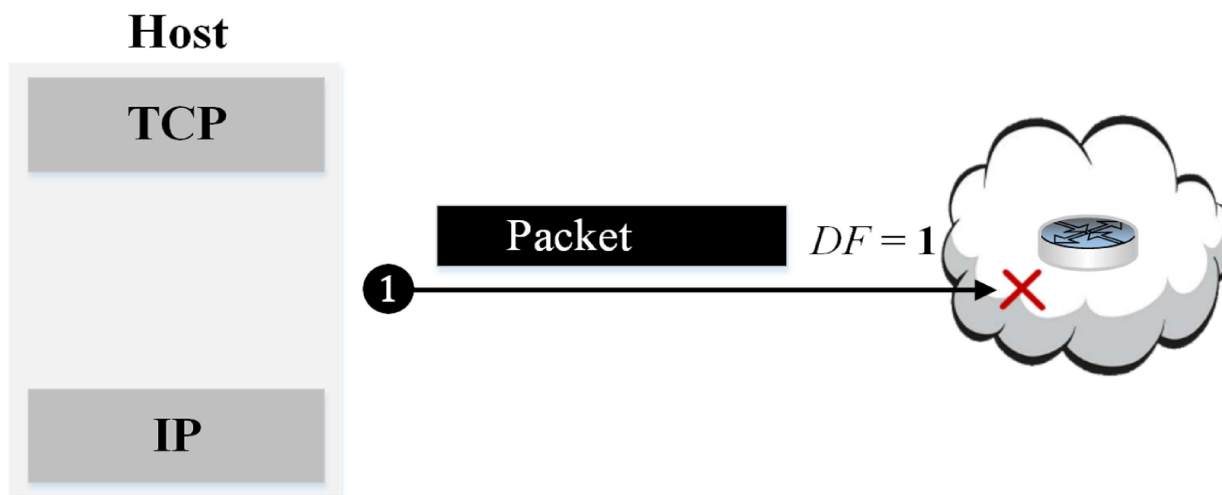
爲了避免IP分片，一些相關技術標準也陸續被提出。例如，RFC1191定義了“**路徑MTU發現 (Path MTU Discovery, PMTUD)**” 機制，該機制用于確定兩台IP主機間的路徑MTU





路徑MTU發現機制

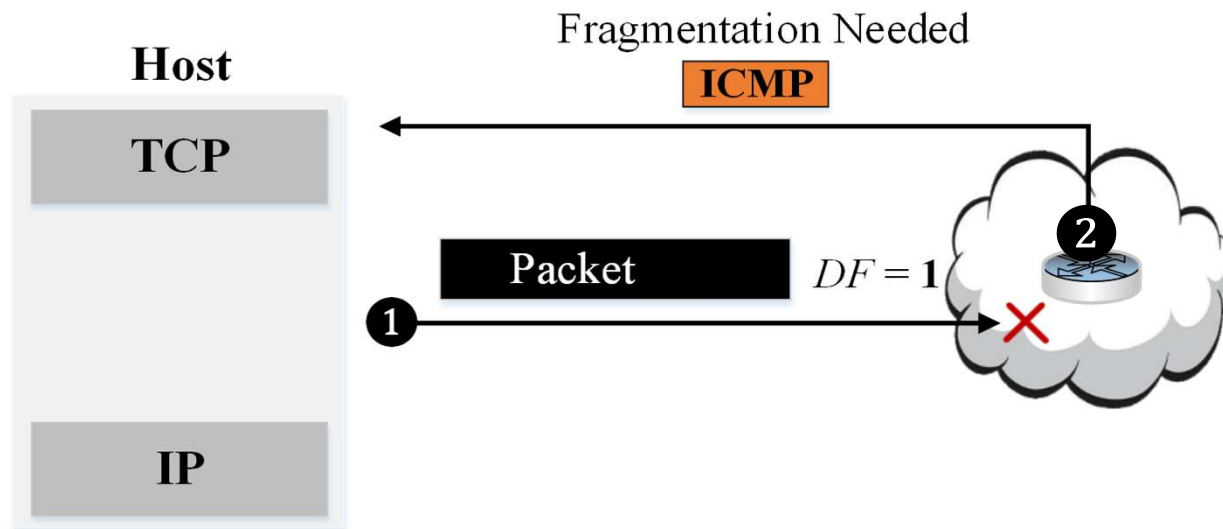
爲了避免IP分片，一些相關技術標準也陸續被提出。例如，RFC1191定義了“**路徑MTU發現 (Path MTU Discovery, PMTUD)**” 機制，該機制用于確定兩台IP主機間的路徑MTU





路徑MTU發現機制

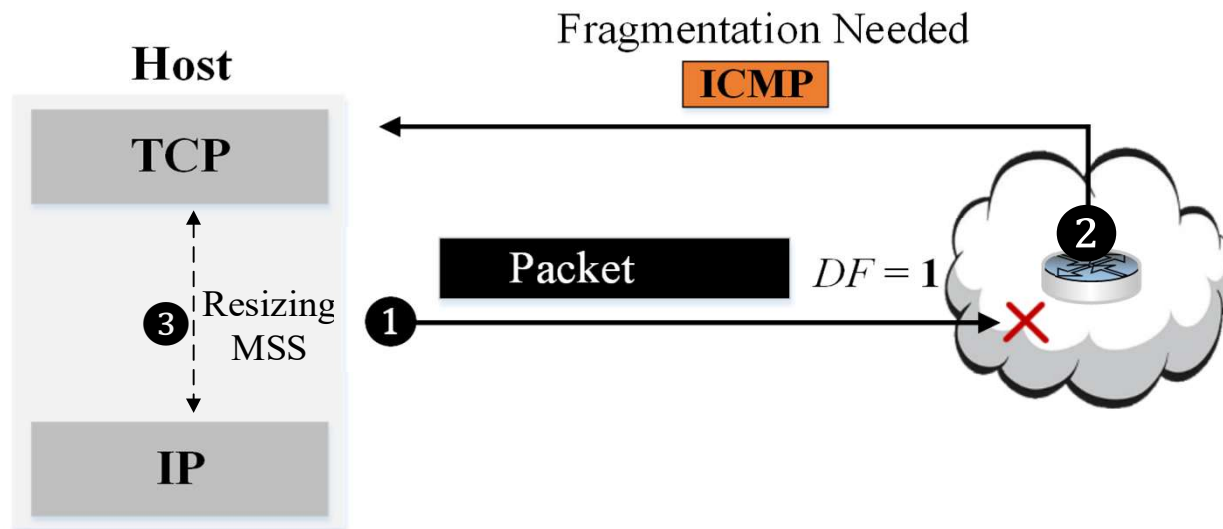
爲了避免IP分片，一些相關技術標準也陸續被提出。例如，RFC1191定義了“**路徑MTU發現 (Path MTU Discovery, PMTUD)**” 機制，該機制用于確定兩台IP主機間的路徑MTU





路徑MTU發現機制

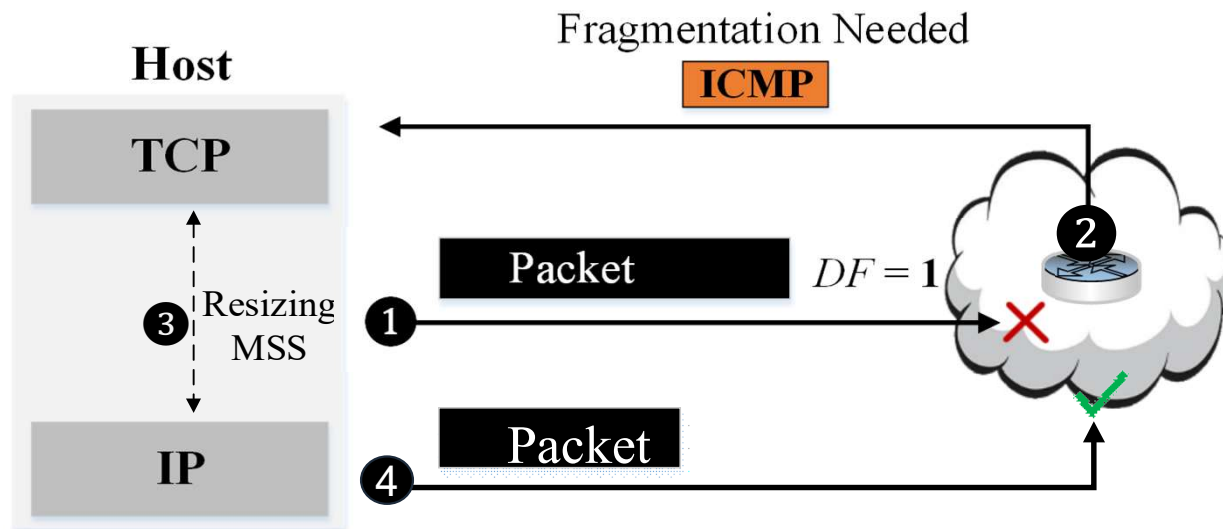
爲了避免IP分片，一些相關技術標準也陸續被提出。例如，RFC1191定義了“**路徑MTU發現 (Path MTU Discovery, PMTUD)**” 機制，該機制用于確定兩台IP主機間的路徑MTU





路徑MTU發現機制

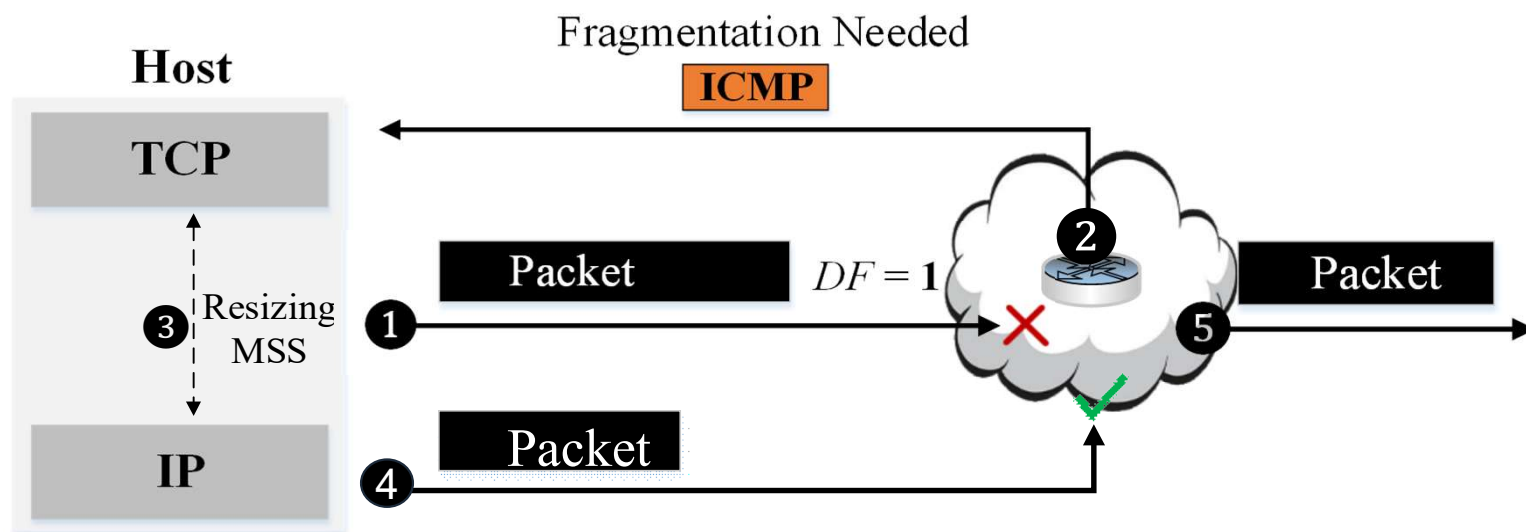
爲了避免IP分片，一些相關技術標準也陸續被提出。例如，RFC1191定義了“**路徑MTU發現 (Path MTU Discovery, PMTUD)**” 機制，該機制用于確定兩台IP主機間的路徑MTU





路徑MTU發現機制

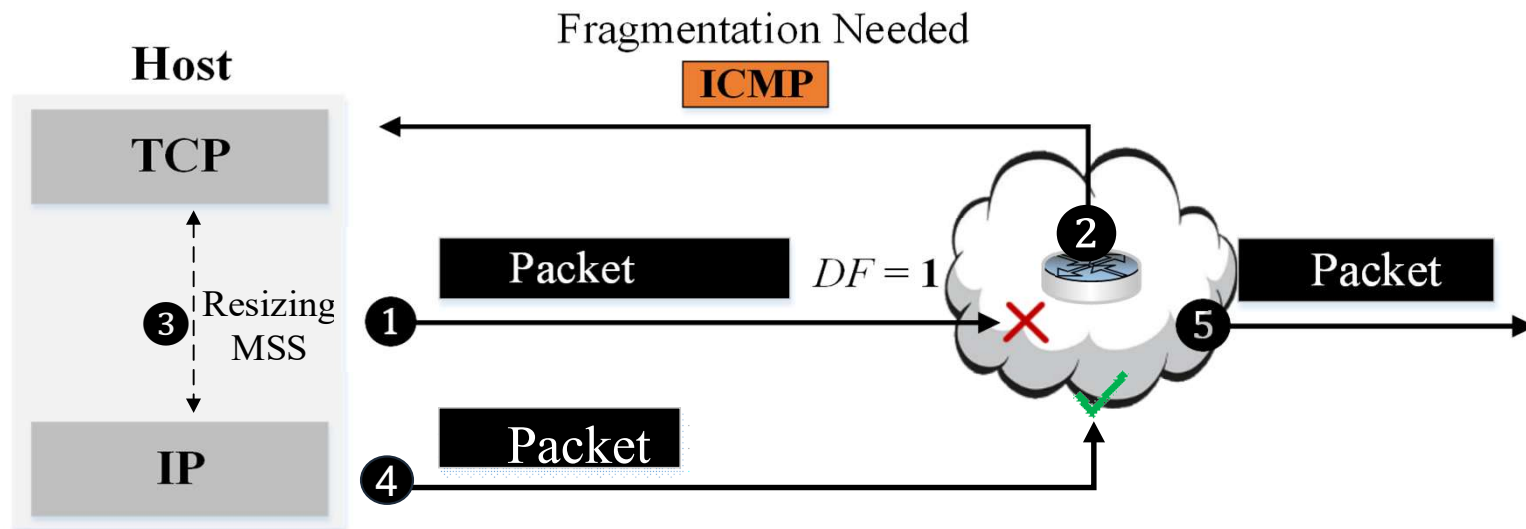
爲了避免IP分片，一些相關技術標準也陸續被提出。例如，RFC1191定義了“**路徑MTU發現 (Path MTU Discovery, PMTUD)**” 機制，該機制用于確定兩台IP主機間的路徑MTU





路徑MTU發現機制

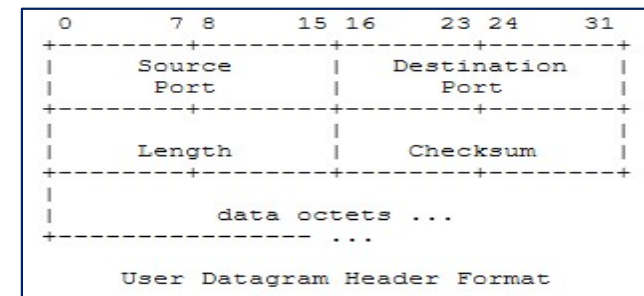
TCP協議有MSS選項，可以通過調整MSS、適合路徑MTU，
從而避免分片，UDP協議？





路徑MTU發現機制

- UDP是面向事務的，與IP層是松耦合的，UDP報文的大小直接**由應用給定**，因此UDP不能依據路徑MTU大小、對傳輸層報文進行適應性調整，即針對UDP報文的IP分片很難避免
- **新的RFC標準**提出，應用層和UDP協議合作、發現路徑MTU，從而避免IP分片，但這些新標準和機制的實際部署，仍需很長時間



Stream: Internet Engineering Task Force (IETF)
RFC: 8899
Updates: 4821, 4960, 6951, 8085, 8261
Category: Standards Track
Published: September 2020
ISSN: 2070-1721
Authors:
G. Fairhurst, T. Jones, M. Tüxen
University of Aberdeen, University of Aberdeen, Münster University of Applied Sciences
I. Rümgeler, T. Völker
Münster University of Applied Sciences, Münster University of Applied Sciences

RFC 8899 Packetization Layer Path MTU Discovery for Datagram Transports

Abstract

This document specifies Datagram Packetization Layer Path MTU Discovery (DPLPMTUD). This is a robust method for Path MTU Discovery (PMTUD) for datagram Packetization Layers (PLs). It allows a PL, or a datagram application that uses a PL, to discover whether a network path can support the current size of datagram. This can be used to detect and reduce the message size when a sender encounters a packet black hole. It can also probe a network path to discover whether the maximum packet size can be increased. This provides functionality for datagram transports that is equivalent to the PLPMTUD specification for TCP, specified in RFC 4821, which it updates. It also updates the UDP Usage Guidelines to refer to this method for use with UDP datagrams and updates SCTP.

The document provides implementation notes for incorporating Datagram PMTUD into IETF datagram transports or applications that use datagram transports.

This specification updates RFC 4960, RFC 4821, RFC 6951, RFC 8085, and RFC 8261.



第4節 傳輸層安全

- ✓ 安全風險一：拒絕服務攻擊
- ✓ 安全風險二：TCP劫持
- ✓ 安全防禦一：TLS協議

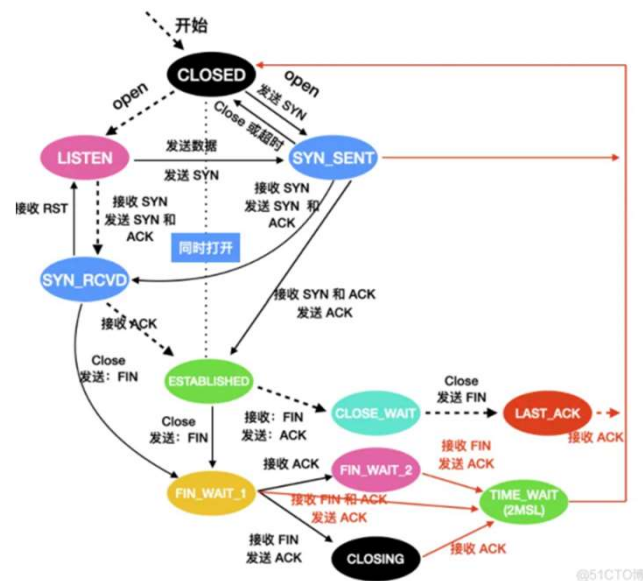


傳輸層功能

傳輸層主要負責提供不同主機應用程序進程之間的端到端的服務

傳輸層的基本功能如下：

- 可靠傳輸
- 按端口號尋址
- 連接管理
- 擁塞控制和流量控制



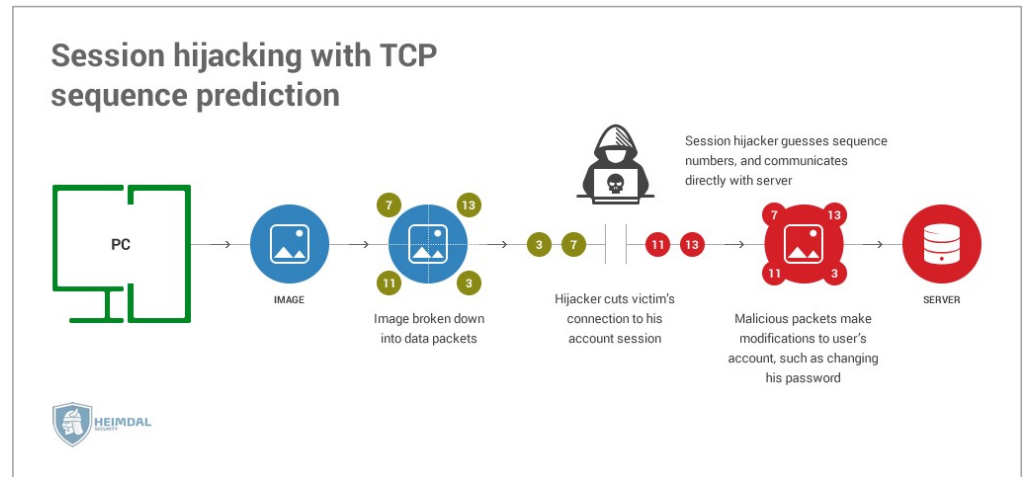
常見的傳輸層協議主要包括兩類：TCP (Transmission Control Protocol) 和UDP (User Datagram Protocol)



TCP劫持攻擊



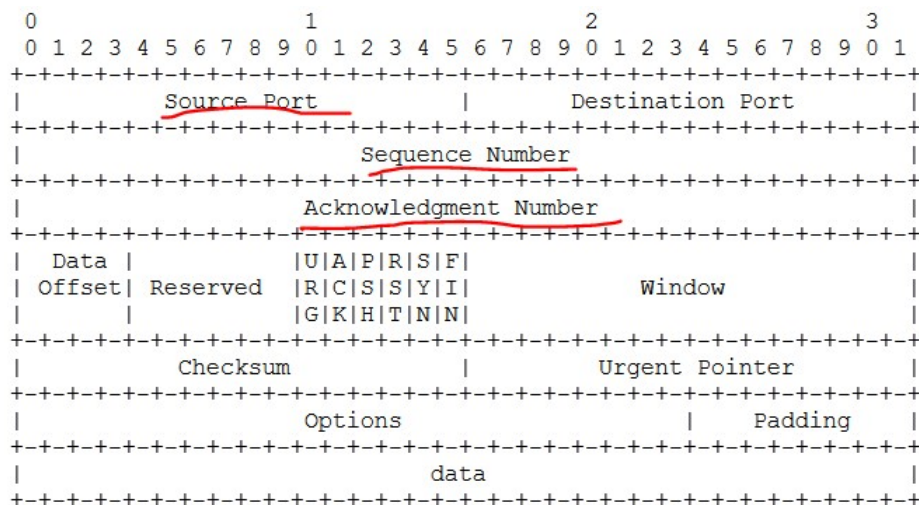
- 相比較針對TCP的DoS攻擊，針對TCP的劫持攻擊是一種更高級、更隱蔽、危害也更大的攻擊方式
- TCP劫持攻擊是指，一個TCP連接外的的非法攻擊者（即Client和Server之外的一個Attacker），將自己偽造的TCP報文，注入到TCP連接雙方的合法數據流中，進而對連接進行攻擊破壞，包括：
 - 偽造控制報文、如RST報文等，惡意**阻斷該連接**
 - 偽造數據報文，**污染數據流**





TCP劫持攻擊

TCP協議的實現引入了**32位隨機的序列號和確認號**，以及**16位隨機的源端口號**，因此攻擊者要成功地將惡意報文注入到目標TCP流中，必須正確預測這些值



如果采用**暴力猜測**的辦法，要求攻擊者的報文發送能力大約在**300M個/秒**，這在實際環境中，顯然很難成功實施，也很容易觸發IDS等安全檢測設備

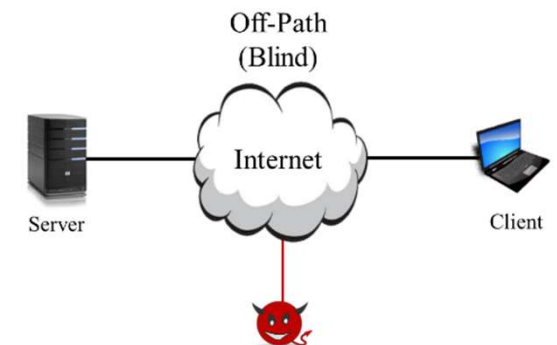
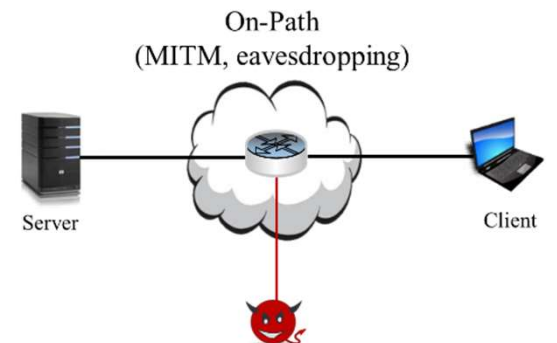
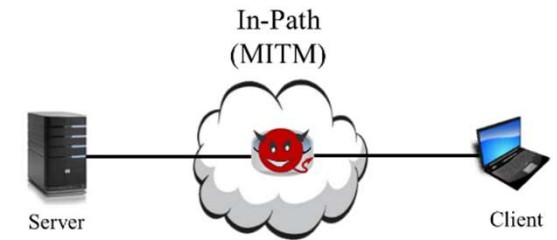


TCP劫持攻擊

依據**攻擊者所處的不同位置**，針對TCP的劫持攻擊，通常有三種攻擊模型：

- In-Path
- On-Path
- Off-Path

在前兩種攻擊模型中，攻擊者能夠嗅探到原始TCP連接的序列號，因此攻擊難度不大。第三種**Off-Path條件**下的TCP劫持攻擊，難度是最大的，也是當前TCP安全的一個研究熱點





基于challenge ACK側信道漏洞的TCP連接劫持

- Challenge ACK是RFC5961裏面定義的一種安全機制，用于提高TCP協議的安全性
- 某主機收到SYN握手包，判斷序列號在有效windows之外，則向發送方回傳ACK；如果序列號in-window，那麼接收方對雙方的連接進行重置
- 該做法缺陷是，攻擊者只需要一個in-windows序列號的SYN包就能重置目標雙方的TCP連接



基于challenge ACK側信道漏洞的TCP連接劫持

- RFC 5961中，接收方收到SYN包後，無論序列號如何，都會回傳一個challenge ACK報文，以便確認先前的連接是否真的已丟失
- 該機制在實現時，爲了提升性能，定義了一個全域的計數器，用于限制challenge ACK的發送速率，而這個全域計數器，成爲了一個側信道漏洞

```
Internet Engineering Task Force (IETF)
Request for Comments: 5961
Category: Standards Track
ISSN: 2070-1721

A. Ramaiah
Cisco
R. Stewart
Huawei
M. Dalal
Cisco
August 2010

Improving TCP's Robustness to Blind In-Window Attacks

Abstract

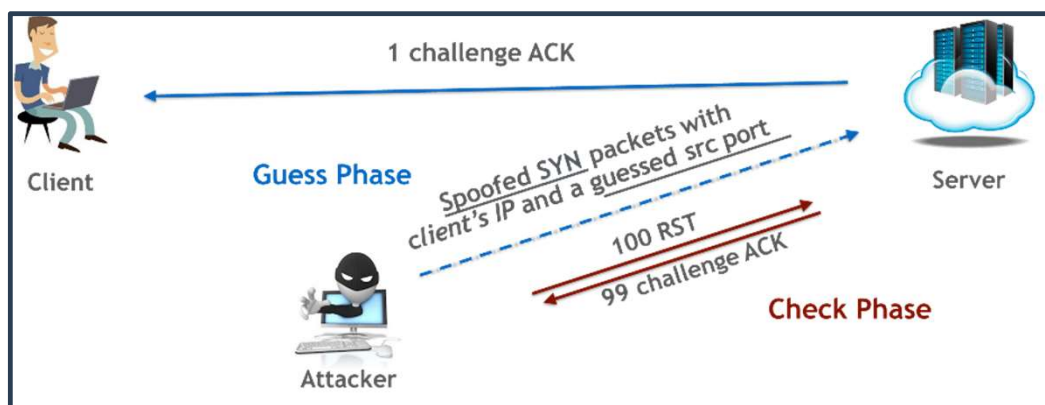
TCP has historically been considered to be protected against spoofed
off-path packet injection attacks by relying on the fact that it is
difficult to guess the 4-tuple (the source and destination IP
addresses and the source and destination ports) in combination with
the 32-bit sequence number(s). A combination of increasing window
sizes and applications using longer-term connections (e.g., H-323 or
Border Gateway Protocol (BGP) [RFC4271]) have left modern TCP
implementations more vulnerable to these types of spoofed packet
injection attacks.

Many of these long-term TCP applications tend to have predictable IP
addresses and ports that makes it far easier for the 4-tuple (4-tuple
is the same as the socket pair mentioned in RFC 793) to be guessed.
Having guessed the 4-tuple correctly, an attacker can inject a TCP
segment with the RST bit set, the SYN bit set or data into a TCP
connection by systematically guessing the sequence number of the
spoofed segment to be in the current receive window. This can cause
the connection to abort or cause data corruption. This document
specifies small modifications to the way TCP handles inbound segments
that can reduce the chances of a successful attack.
```

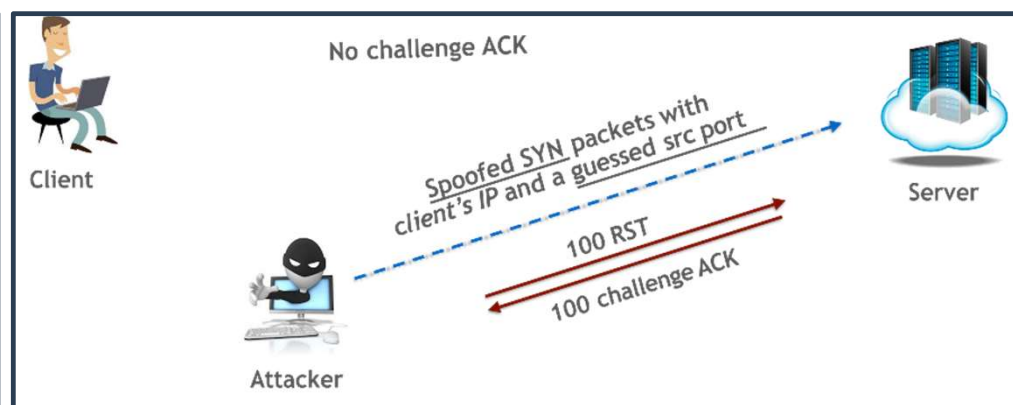


基于challenge ACK側信道漏洞的TCP連接劫持

- 一秒鐘最多發100個challenge ACK，而且在各個連接之間共享，所以攻擊者先偽造用戶地址發一個RST包，然後再用自己的連接發100個RST包，如果收到100個challenge ACK，說明沒猜對，收到99個，說明猜對了
- 一個旁路的攻擊者，可以通過**觀測**該側信道漏洞，**猜測**出TCP連接的三個主要參數，即源端口號、序列號、確認號，進而構造偽造報文，劫持目標TCP連接



參數猜測**成功**



參數猜測**不成功**



TLS協議及發展歷史

傳輸層安全性協議 (Transport Layer Security, TLS) 及其前身安全套接層協議 (Secure Sockets Layer, SSL) 是一種廣泛採用的安全性協議，旨在促進 Internet 上通信的隱私和數據安全性

- 1994年，NetScape公司設計了SSL協議 (Secure Sockets Layer) 的1.0版，但是未發布
- 1995年，NetScape公司發布SSL 2.0版，很快發現有嚴重漏洞
- 1996年，SSL 3.0版問世，得到大規模應用
- 1999年，互聯網標準化組織IETF接替NetScape公司，發布了SSL的升級版TLS1.0版
- 2006年和2008年，TLS進行了兩次升級，分別為TLS 1.1版和TLS 1.2版
- 2011年，TLS 1.2修訂版發布
- 2018年，TLS 1.3發布

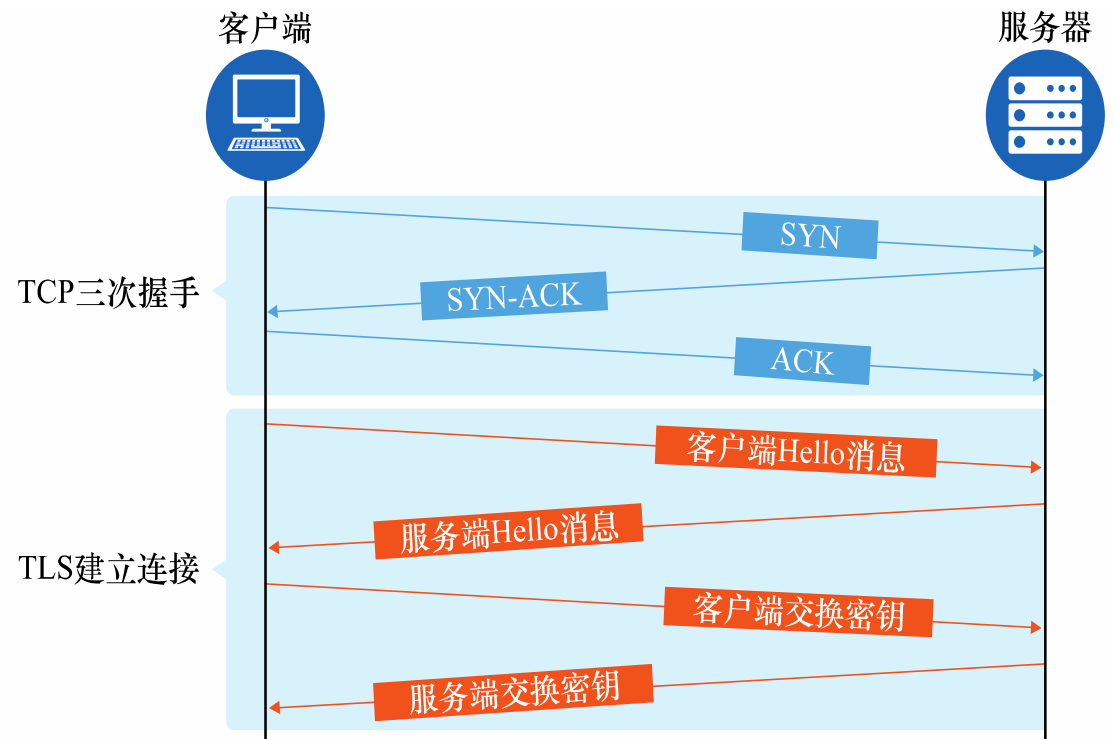




TLS協議工作過程

(1) 客戶端（通常是瀏覽器）
先向服務器發出加密通信的請求，
稱為ClientHello請求

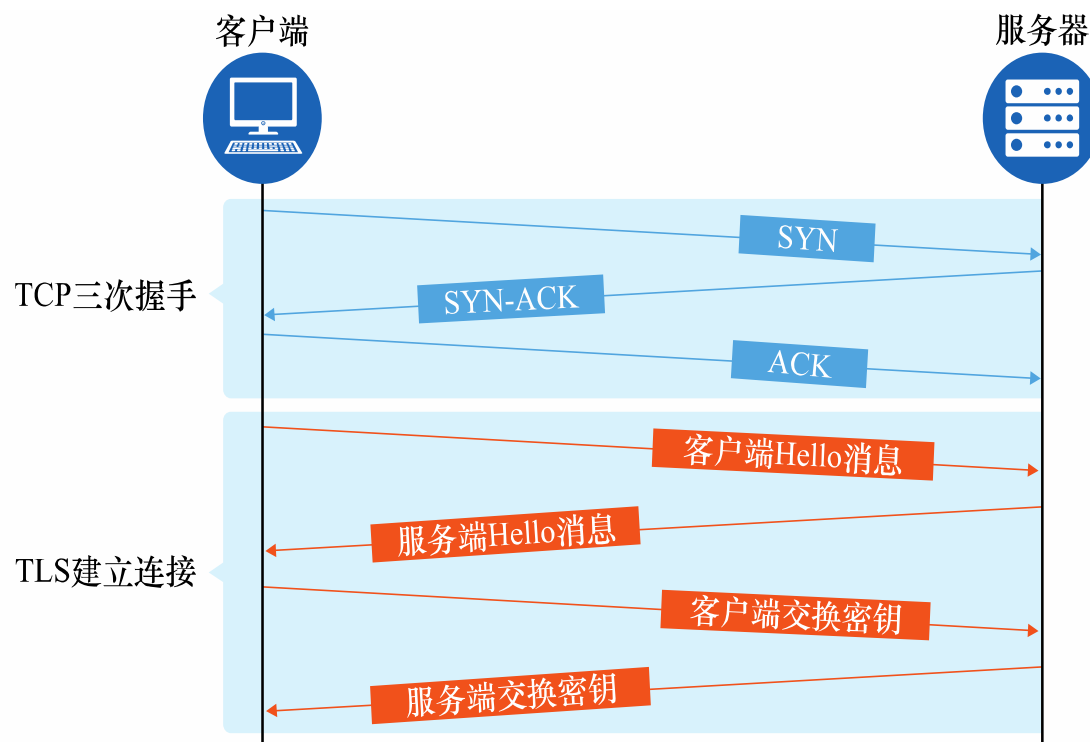
(2) 服務器收到客戶端請求後，
向客戶端發出回應，稱為
ServerHello，提供服務器證書
等信息





TLS協議工作過程

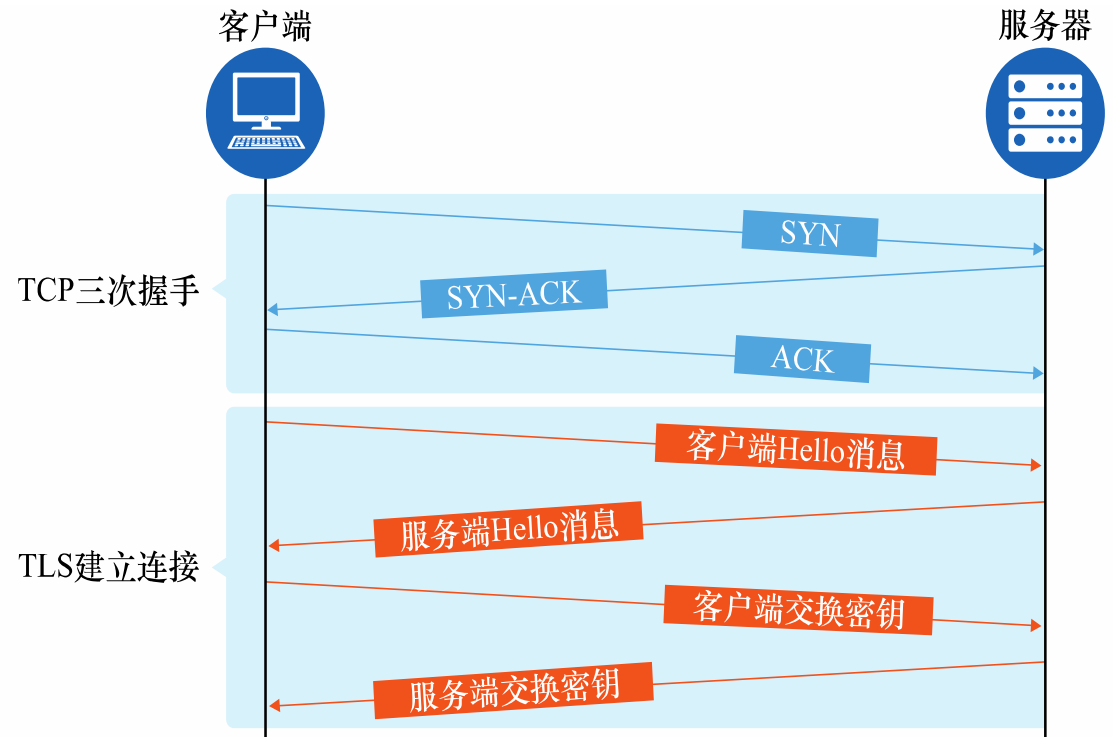
(3) 客戶端驗證服務器證書。
如果證書不可信，向訪問者顯示一個警告，由其選擇是否還要繼續通信。如果證書沒有問題，客戶端就會從證書中取出服務器的公鑰，並加密發送協商的隨機數（用于生成會話密鑰）等信息





TLS協議工作過程

(4) 服務器收到客戶端的隨機數信息後，計算生成本次會話所用的“會話密鑰”，然後向客戶端最後發送確認信息，結束握手過程





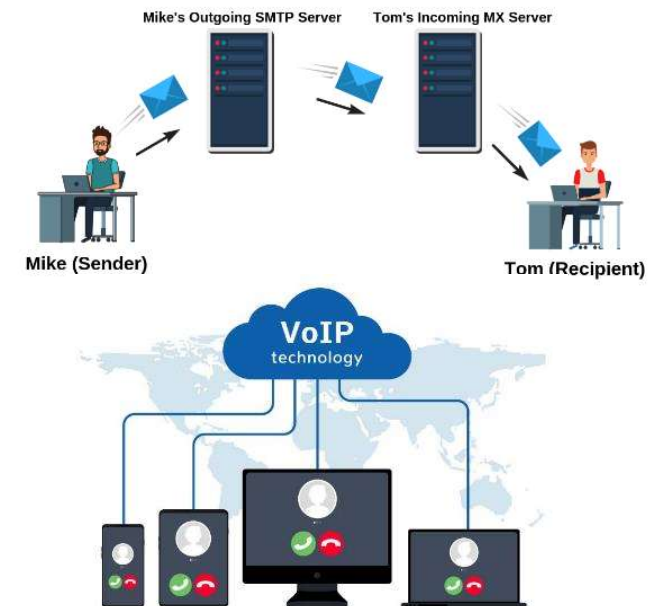
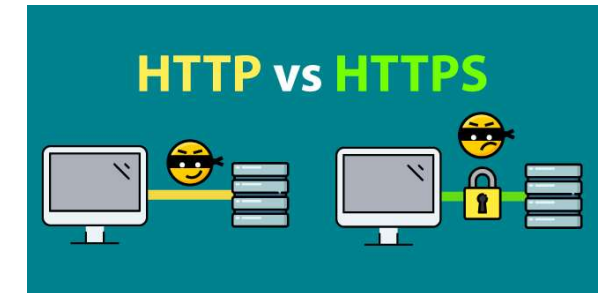
TLS協議功能及應用

TLS 協議通常在TCP等傳輸層協議之上運行，提供以下三個安全功能：

- **加密**：阻止第三方對傳輸數據的竊聽
- **身份驗證**：確保交換信息的各方是他們聲稱的身份
- **完整性**：驗證數據是否偽造而來或未遭篡改過

廣泛應用：

TLS是目前采用最廣泛的一種安全性協議，應用于多個網絡場景，如：對Web 應用程序和服務器之間的通信進行加密保護，還可用于電子郵件、消息傳遞和 IP 語音（VoIP）加密等





第6節 網絡安全共性分析

- ✓ 網絡攻擊的共性特徵
- ✓ 協議棧的設計缺陷和實現漏洞
- ✓ 協議棧安全的基本防禦原理



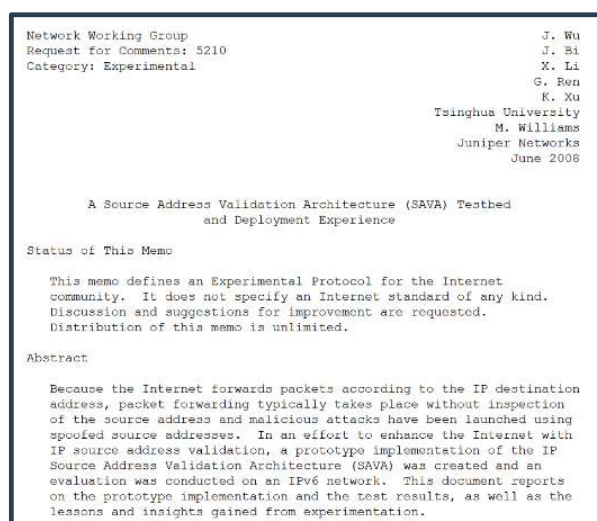
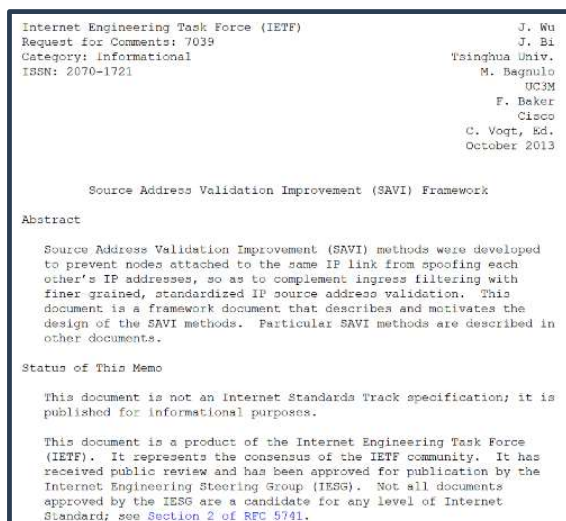
協議棧安全的基本防禦原理

基于真實源地址的網絡安全防禦

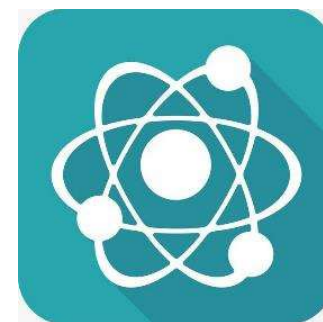
當前已經有一些標準規範推出，如RFC7039，RFC5210等，進行**網絡源地址驗證**，約束主機只能使用預分配給自己的IP地址發送數據，進行網絡通信

增強協議棧隨機化屬性

通過增強網絡協議棧的隨機化屬性，提升攻擊者猜測、推理出目標網絡狀態信息的難度。代表性的包括**移動目標防禦**（Moving Target Defense, MTD），**擬態防禦**等



MORPHISEC
Moving Target Defense





第7節 總結和展望



總結



展望



總結

概述TCP/IP 協議棧中存在的安全問題，基于其共性特徵給出了基本的防禦思路



第一節

TCP/IP協議工作原理

- 協議棧中消息縱向傳遞
- 協議棧中消息橫向傳遞

協議棧的層次化架構以及消息傳遞模式注定了其存在安全隱患



第二節

鏈路層安全

- ARP欺騙與污染
- 網絡監聽與嗅探



第三節

網絡層安全

- 源地址假冒攻擊
- IP分片攻擊原理
- ICMP攻擊原理
- IPSec協議
- 網絡入侵檢測



第四節

傳輸層安全

- 拒絕服務攻擊
- TCP劫持攻擊
- TLS協議



第五節

典型案例分析

- 交互信息泄露
- 幀長側信道
- 交互二義性
- 交互語義缺失
- 交互身份欺騙
- NAT劫持



第六節

網絡安全共性分析

- 網絡攻擊的共性特徵
- 協議棧設計缺陷和實現漏洞
- 協議棧安全的基本防禦原理

多樣化的網絡攻擊

利用基于真實地址的安全防禦以及網絡狀態隨機化來抵禦網絡攻擊



總結：層間交互安全分析

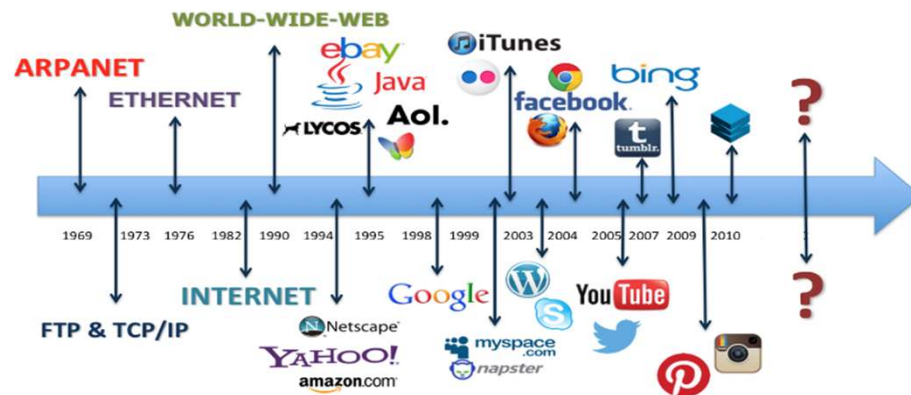
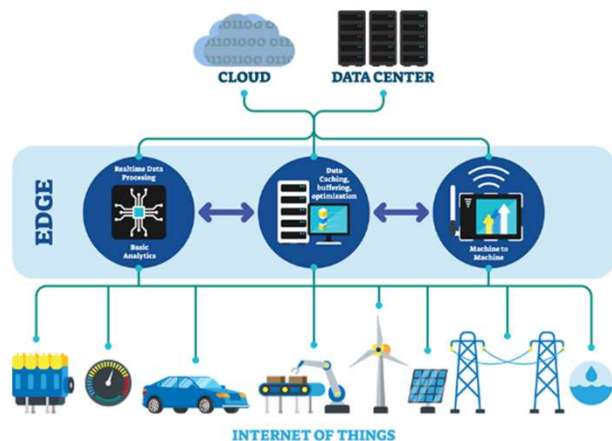
即使每一層協議的實現都足夠安全魯棒，也並不意味著整個協議棧實現沒有安全風險





展望

Edge Computing



- 隨著雲、邊、端等多樣化網絡場景和應用的不斷涌現，基礎的 TCP/IP 協議將面臨更多的挑戰，與安全性相關的威脅挑戰也將是未來的研究熱點
- 加強協議交互安全審計、保證不同版本間協議語義的一致性；借助機器學習等技術手段、自動化地挖掘檢測協議棧中的安全漏洞等，都將是未來協議棧安全的主要研究方向